Lucerne University of
Applied Sciences and Arts

HOCHSCHULE
LUZERN

Informatik

Information Security Management
02 Grundschutz-Kompendium nach BSI

HSLU – Informatik

Mathias Bücherl (M.Sc.)

Tel. +41 79 746 10 98

mathias.buecherl@hslu.ch

Material von Prof. Dr. Peter E. Fischer, Prof. Armand Portmann und Oliver Hirschi

Ziele

- Sie kennen die Ziele, Struktur, Aufbau und Inhalte des BSI-Grundschutz-Kompendiums
- Sie differenzieren zwischen neuer und alter Methodik
- Sie begreifen die Grundlagen der Zertifizierung
- Sie können die neue Methodik anwenden
- Sie verstehen den Grundschutz mit Tiefgang

AGENDA

1. **Motivation und Einführung**
2. Neue Methodik
3. Zertifizierung
4. Kreuzreferenztabellen
5. Kombinierte Risiko-Analyse nach BSI 200-3
6. Fazit und Aufgaben
7. Vertiefung

Idee des IT-Grundschutzes

- Abläufe und IT-Komponenten sind überall ähnlich
  - Typische Gefährdungen, Schwachstellen und Risiken
  - Typische Geschäftsprozesse und Anwendungen
  - Typische IT-Komponenten
- Darauf aufbauend kann ein Gerüst für das Sicherheitsmanagement erstellt werden
- Zentrale Aspekte
  - Wiederverwendbarkeit
  - Anpassbarkeit
  - Erweiterbarkeit

© Hochschule Luzern – Informatik

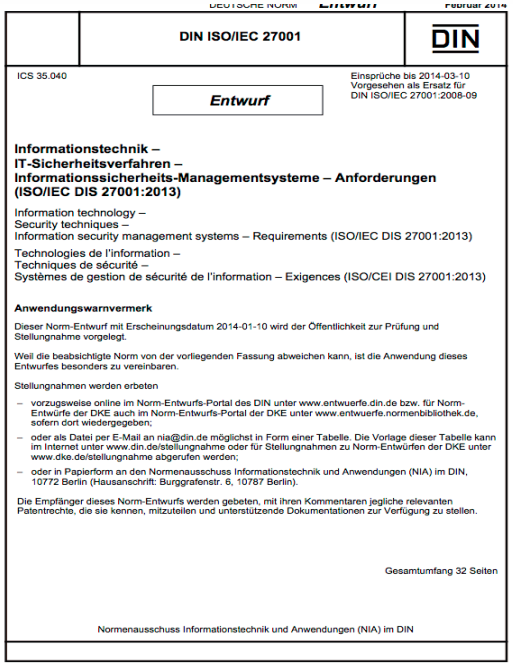
Idee des IT-Grundschutzes

- Infrastrukturelle, organisatorische, personelle und technische **Standard-Sicherheitsmassnahmen** helfen, ein **Standard-Sicherheitsniveau** aufzubauen, um geschäftsrelevante Informationen zu schützen

Nutzen der IT-Grundschutz-Kataloge

- Aufwand für die Entwicklung eines Sicherheitskonzepts reduzieren
- In der Regel genügt es, die auf den Einsatzzweck zutreffenden Bausteine auszuwählen und die darin enthaltenen Massnahmen einzuplanen und konsequent umzusetzen

Motivation und Ziel



DEUTSCHE NORM Entwurf Februar 2014

DIN ISO/IEC 27001

DIN

ICS 35.040

Einsprüche bis 2014-03-10
Vorgesehen als Ersatz für
DIN ISO/IEC 27001:2008-09

Entwurf

**Informationstechnik –
IT-Sicherheitsverfahren –
Informationssicherheits-Managementsysteme – Anforderungen
(ISO/IEC DIS 27001:2013)**

Information technology –
Security techniques –
Information security management systems – Requirements (ISO/IEC DIS 27001:2013)

Technologies de l'information –
Techniques de sécurité –
Systèmes de gestion de sécurité de l'information – Exigences (ISO/CEI DIS 27001:2013)

Anwendungswarnvermerk

Dieser Norm-Entwurf mit Erscheinungsdatum 2014-01-10 wird der Öffentlichkeit zur Prüfung und Stellungnahme vorgelegt.

Weil die beabsichtigte Norm von der vorliegenden Fassung abweichen kann, ist die Anwendung dieses Entwurfes besonders zu vereinbaren.

Stellungnahmen werden erbeten

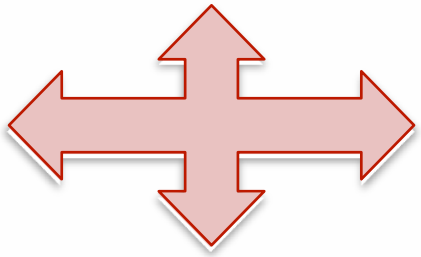
- vorzugsweise online im Norm-Entwurfs-Portal des DIN unter www.entwuerfe.din.de bzw. für Norm-Entwürfe der DKE auch im Norm-Entwurfs-Portal der DKE unter www.entwuerfe.normenbibliothek.de, sofern dort wiedergegeben;
- oder als Datei per E-Mail an nia@din.de möglichst in Form einer Tabelle. Die Vorlage dieser Tabelle kann im Internet unter www.din.de/stellungnahme oder für Stellungnahmen zu Norm-Entwürfen der DKE unter www.dke.de/stellungnahme abgerufen werden;
- oder in Papierform an den Normenausschuss Informationstechnik und Anwendungen (NIA) im DIN, 10772 Berlin (Hausanschrift: Burggrafenstr. 6, 10787 Berlin).

Die Empfänger dieses Norm-Entwurfs werden gebeten, mit ihren Kommentaren jegliche relevanten Patentrechte, die sie kennen, mitzuteilen und unterstützende Dokumentationen zur Verfügung zu stellen.

Gesamtumfang 32 Seiten

Normenausschuss Informationstechnik und Anwendungen (NIA) im DIN









Sie verstehen den Aufbau des BSI Grundschutz-Kompendiums (BSI=Bundesamt für Sicherheit in der Informationstechnik, Deutschland)

© Hochschule Luzern – Informatik

Bundesamt für Sicherheit in der Informationstechnik (BSI)

- Gründung des BSI: 1. Januar 1991
- Amtssitz: Godesberger Allee 185-189, 53175 Bonn
- Stellenzahl: 1.289,2 (Stand 2019)
- Budget/Haushalt: 117,9 Millionen Euro (2018)
- Präsident: Arne Schönbohm (seit 2016)
- Vizepräsident: Dr. Gerhard Schabhüser (seit 2017)
  Standort: Bonn
- Kunden: Bundesverwaltung, Wirtschaft, Wissenschaft, Bürger

BSI-Standards, IT-Grundschutz-Kompendium



- Die **BSI-Standards** beschreiben die Vorgehensweise nach IT-Grundschutz und enthalten Ausführungen zum Informations-sicherheitsmanagement und zur Risikoanalyse



- Das **IT-Grundschutz-Kompendium** beinhaltet die Bausteine, Gefährdungen und Umsetzungshinweise (statt Massnahmen)
  - 8 Domainen, über 80 Bausteine
  - Umsetzung in den Bausteinen enthalten
  - 816 statt vorher über 4000 Seiten

BSI Standards und GS-Kompendium

BSI-Standards zur Informationssicherheit

Informationssicherheit und IT-Grundschutz

BSI-Standard 200-1
Managementsysteme für Informationssicherheit (ISMS)

BSI-Standard 200-2
IT-Grundschutz-Methodik

BSI-Standard 200-3
Risikoanalyse auf der Basis von IT-Grundschutz

BSI-Standard 100-4
Notfallmanagement

IT-Grundschutz-Kompendium

Kapitel 1 Vorspann
Kapitel 2 Schichtenmodell und Modellierung

Elementare Gefährdungen

Schichten

Prozess-Bausteine:
- ISMS (Sicherheitsmanagement)
- ORP (Organisation & Personal)
- CON (Konzepte & Vorgehensweise)
- OPS (Betrieb)
- DER (Detektion & Reaktion)

System-Bausteine:
- IND (Industrielle IT)
- APP (Anwendungen)
- SYS (IT-Systeme)
- NET (Netze & Kommunikation)
- INF (Infrastruktur)

AGENDA

1. Motivation und Einführung
2. **Neue Methodik**
3. Zertifizierung
4. Kreuzreferenztabellen
5. Kombinierte Risiko-Analyse nach BSI 200-3
6. Fazit und Aufgaben
7. Vertiefung

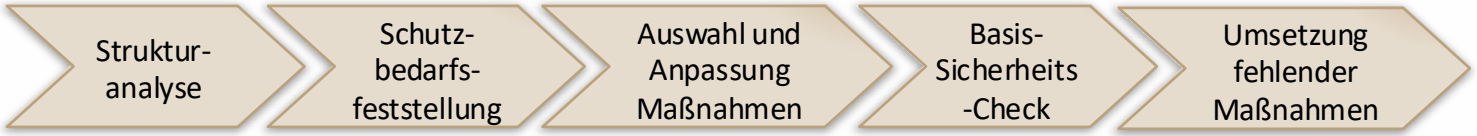
Annäherung der Standards

- IT-Grundschutz Kompendium definiert Anforderungen
- => konkreter ausgestaltet als Anforderungen der ISO 27001
- Gliederung der Anforderungen in BASIS – STANDARD - HOHER SCHUTZBEDARF sowie en Detail in MUSS – SOLL - KANN
- Anforderungen der Standardabsicherung entsprechen einem «normalen Schutzbedarf» und Basis für eine Zertifizierung «ISO 27001 nach IT-Grundschutz»
- Zu den Anforderungen existieren detaillierte Umsetzungshinweise mit entsprechenden Maßnahmenvorschlägen (analog ISO 27002)

  → auch diese sind deutlich konkreter / umfassender
- Mit BSI 200-3 gibt es eine konsistente Methode zur Risikoanalyse
- (ISO 27005 wurde noch nicht an die Version 2013 angepasst, ISO 31000 ist generisch)

Neue Methodik

Vorgehensweise nach BSI 100-2



Erfolgt auf Basis der Bausteine mit vorgegebenen Maßnahmen

Maßnahmen (weitgehend) vorgegeben

Vorgehensweise nach BSI 200-2



Erfolgt auf Basis von Anforderungen

Welche Anforderungen sind wie realisiert ? => Umgesetzte Maßnahmen identifizieren und bewerten

Zu welchen Anforderungen fehlen noch geeignete Maßnahmen?

Maßnahmen können frei gewählt werden

Annäherung der Methodik von Grundschutz und ISO 27001

Beispiel: ANFORDERUNGEN Zutrittskontrolle (1:1)

A.11.1.2	Physische Zugangskontrolle	*Maßnahme* Sicherheitsbereiche müssen durch angemessene Zugriffskontrollen geschützt werden, durch die sichergestellt ist, dass nur autorisiertes Personal Zugriff hat.
A.11.1.3	Sicherung von Zweigstellen,	*Maßnahme*

Quelle: DIN ISO/IEC 27001:2014-02 , Anhang A

ISO 27001
Anhang A

IT-Grundschutz | INF.1 Allgemeines Gebäude

(Basisanforderung)

INF.1.A7 Zutrittsregelung und -kontrolle [Leiter Organisation]

Der Zutritt zu schutzbedürftigen Gebäudeteilen und Räumen MUSS geregelt und kontrolliert werden. Es SOLLTE ein Konzept für die Zutrittskontrolle existieren. Die Zahl der zutrittsberechtigten Personen SOLLTE für jeden Bereich auf ein Mindestmaß reduziert werden. Weitere Personen DÜRFEN erst nach vorheriger Prüfung der Notwendigkeit Zutritt erhalten. Alle erteilten Zutrittsberechtigungen SOLLTEN dokumentiert werden. Die Zutrittskontroll-Maßnahmen MÜSSEN regelmäßig auf ihre Wirksamkeit überprüft werden.

Quelle: IT-Grundschutz, INF.1 Allgemeines Gebäude, Community Draft (Webseiten des BSI)

„MUSS“ / „DARF NUR“
verpflichtende Anteile

„SOLL“
Abweichung mit Begründung möglich

„KANN“
Fakultativ, best practice

Die IT-Grundschutz Anforderungen sind konkreter ausgestaltet als die korrespondierenden Anforderungen der ISO 27001

Beispiel: ANFORDERUNGEN Backup (1:n)

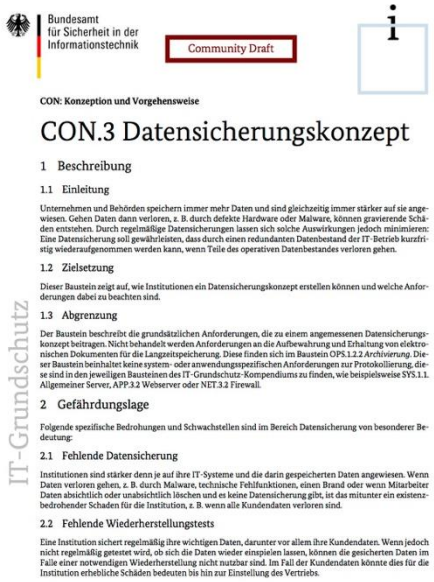
A.12.3 Datensicherungen

Ziel: Schutz vor Datenverlust

A.12.3.1	Datensicherungen	*Maßnahme* Es sind Sicherungskopien von Daten und Software sowie System-Images anzufertigen und regelmäßig entsprechend der vereinbarten Sicherungsleitlinie zu prüfen.

Quelle: DIN ISO/IEC 27001:2014-02 , Anhang A

1 Anforderung ISO
:
12 Anforderungen GS
(ganzer Baustein)



Bundesamt für Sicherheit in der Informationstechnik

Community Draft

CON: Konzeption und Vorgehensweise

CON.3 Datensicherungskonzept

1 Beschreibung

1.1 Einleitung

Unternehmen und Behörden speichern immer mehr Daten und sind gleichzeitig immer stärker auf sie angewiesen. Gehen Daten dann verloren, z. B. durch defekte Hardware oder Malware, können gravierende Schäden entstehen. Durch regelmäßige Datensicherungen lassen sich solche Auswirkungen jedoch minimieren: Eine Datensicherung soll gewährleisten, dass durch einen redundanten Datenbestand der IT-Betrieb kurzfristig wiederaufgenommen werden kann, wenn Teile des operativen Datenbestandes verloren gehen.

1.2 Zielsetzung

Dieser Baustein zeigt auf, wie Institutionen ein Datensicherungskonzept erstellen können und welche Anforderungen dabei zu beachten sind.

1.3 Abgrenzung

Der Baustein beschreibt die grundsätzlichen Anforderungen, die zu einem angemessenen Datensicherungskonzept beitragen. Nicht behandelt werden Anforderungen an die Aufbewahrung und Erhaltung von elektronischen Dokumenten für die Langzeitspeicherung. Diese finden sich im Baustein OPS.1.2.2 *Archivierung*. Dieser Baustein beinhaltet keine system- oder anwendungsspezifischen Anforderungen zur Protokollierung, diese sind in den jeweiligen Bausteinen des IT-Grundschutz-Kompendiums zu finden, wie beispielsweise SYS.1.1. Allgemeiner Server, APP.3.2 Webserver oder NET.3.2 Firewall.

2 Gefährdungslage

Folgende spezifische Bedrohungen und Schwachstellen sind im Bereich Datensicherung von besonderer Bedeutung:

2.1 Fehlende Datensicherung

Institutionen sind stärker denn je auf ihre IT-Systeme und die darin gespeicherten Daten angewiesen. Wenn Daten verloren gehen, z. B. durch Malware, technische Fehlfunktionen, einen Brand oder wenn Mitarbeiter Daten absichtlich oder unabsichtlich löschen und es keine Datensicherung gibt, ist das mitunter ein existenzbedrohender Schaden für die Institution, z. B. wenn alle Kundendaten verloren sind.

2.2 Fehlende Wiederherstellungstests

Eine Institution sichert regelmäßig ihre wichtigen Daten, darunter vor allem ihre Kundendaten. Wenn jedoch nicht regelmäßig getestet wird, ob sich die Daten wieder einspielen lassen, können die gesicherten Daten im Falle einer notwendigen Wiederherstellung nicht nutzbar sind. Im Fall der Kundendaten könnte dies für die Institution erhebliche Schäden bedeuten bis hin zur Einstellung des Vertriebs.

IT-Grundschutz

Quelle: IT-Grundschutz, CON 3Datensicherungskonzept, Community Draft (Webseiten des BSI)

CON.3.A1 Erhebung der Einflussfaktoren der Datensicherung
CON.3.A2 Festlegung der Verfahrensweise für die Datensicherung
CON.3.A3 Ermittlung von rechtlichen Einflussfaktoren
CON.3.A4 Erstellung eines Minimaldatensicherungskonzeptes
CON.3.A5 Regelmäßige Datensicherung

Standardanforderungen

CON.3.A6 Entwicklung eines Datensicherungskonzepts
CON.3.A7 Beschaffung eines geeigneten Datensicherungssystems
CON.3.A8 Funktionstests und Überprüfung der Wiederherstellbarkeit
CON.3.A9 Voraussetzungen für die Online-Datensicherung
CON.3.A10 Verpflichtung der Mitarbeiter zur Datensicherung
CON.3.A11 Sicherungskopie der eingesetzten Software
CON.3.A12 Geeignete Aufbewahrung der Backup-Datenträger

Anforderungen bei erhöhtem Schutzbedarf

CON.3.A13 Einsatz kryptografischer Verfahren bei der Datensicherung

aber

Die Anforderungen des Bausteins entsprechen weitgehend den Umsetzungshinweisen der ISO 27002

Umsetzungshinweise

11.1.2 Physische Zugangskontrollen

Maßnahme

Sicherheitsbereiche sollten durch angemessene Zugangskontrollen geschützt werden, durch die sichergestellt ist, dass nur autorisiertes Personal Zugang hat.

Umsetzungshinweise

Die folgenden Leitlinien sollten dabei berücksichtigt werden:

a) An- und Abmeldung von Besuchern sollten mit Datum und Uhrzeit vermerkt werden, und alle Besucher sollten kontrolliert werden, sofern ihr Aufenthalt nicht zuvor genehmigt wurde. Besuchern sollte der Zutritt nur für spezifische, genehmigte Zwecke gestattet werden, und sie sollten bezüglich der Sicherheitsanforderungen im betreffenden Bereich sowie der Notfallmaßnahmen eingewiesen werden. Die Identität der Besucher sollte auf geeignete Weise bestätigt werden;

b) Der Zugang zu Bereichen, in denen vertrauliche Informationen verarbeitet oder gespeichert werden, sollte mittels geeigneter Zugangskontrollen wie z. B. eines aus einer Zugangskarte und einer geheimen PIN bestehenden Zwei-Faktor-Authentifizierungsmechanismus autorisierten Personen vorbehalten werden;

c) Es sollten ein physisches Protokollbuch oder ein elektronischer Prüfpfad existieren, die sicher aufbewahrt und überwacht werden;

d) Alle Mitarbeiter, Auftragnehmer und externen Parteien sollten dazu verpflichtet werden, eine gut sichtbare Kennzeichnung zu tragen und unverzüglich das Sicherheitspersonal zu benachrichtigen, wenn sie auf unbegleitete Besucher oder Personen treffen, die keine erkennbare Kennzeichnung tragen;

e) Mitarbeitern externer Support-Dienstleister sollte nur dann beschränkter Zugang zu Sicherheitsbereichen oder Einrichtungen zur Verarbeitung vertraulicher Informationen gewährt werden, wenn dies erforderlich ist. Dieser Zugang sollte eigens genehmigt und überwacht werden;

f) Zugangsrechte in Bezug auf Sicherheitsbereiche sollten regelmäßig überprüft und aktualisiert sowie, sofern erforderlich, wieder entzogen werden (siehe 9.2.4 und 9.2.5).

Umsetzungshinweise aus ISO 27002:2013

Die Umsetzungshinweise des IT-Grundschutz sind konkret, sie enthalten aber keine vorgegebenen Maßnahmen mehr.

INF.1.M7 Zutrittsregelung und -kontrolle

Der Zutritt zu schutzbedürftigen Gebäudeteilen und Räumen ist zu regeln und zu kontrollieren (siehe ORP.4 Identitäts- und Berechtigungsmanagement). Die Maßnahmen reichen dabei von einer einfachen Schlüsselvergabe bis zu aufwendigen Identifizierungssystemen mit Personenvereinzelung.

Für eine Zutrittsregelung und -kontrolle ist es erforderlich, dass

- der von der Regelung betroffene Bereich eindeutig bestimmt wird,
- die Zahl der zutrittsberechtigten Personen auf ein Mindestmaß reduziert wird; diese Personen sollen gegenseitig ihre Berechtigung kennen, um Unberechtigte als solche erkennen zu können,
- der Zutritt anderer Personen (Besucher) erst nach vorheriger Prüfung der Notwendigkeit erfolgt,
- erteilte Zutrittsberechtigungen dokumentiert werden.

Die Vergabe von Rechten allein reicht nicht aus, wenn deren Einhaltung oder Überschreitung nicht kontrolliert wird. Die Ausgestaltung von Kontrollmechanismen sollte nach dem Grundsatz erfolgen, dass einfache und praktikable Lösungen oft ebenso effizient sind wie aufwendige Technik. Beispiele hierfür sind:

- Information und Sensibilisierung der Berechtigten,
- Bekanntgabe von Berechtigungsänderungen,
- sichtbares Tragen von Hausausweisen, ergänzt durch Vergabe von Besucherausweisen,
- Begleitung von Besuchern,
- Verhaltensregelungen bei erkannter Berechtigungsüberschreitung und
- Einschränkung des ungehinderten Zutritts für nicht Zutrittsberechtigte (z. B. Tür mit Blindknauf, Schloss für Berechtigte mit Schlüssel, Klingel für Besucher).

Bei der Zutrittskontrolle werden verschiedene bauliche, organisatorische und personelle Maßnahmen benötigt. Deren Zusammenwirken sollte in einem Zutrittskontrollkonzept geregelt sein, das die generellen Richtlinien für den Perimeter-, Gebäude- und Geräteschutz festlegt. Dazu gehören:

- Festlegung der Sicherheitszonen
  Zu schützende Bereiche können etwa Grundstücke, Gebäude, Serverräume, Räume mit Peripheriegeräten, Archive, Kommunikationseinrichtungen und die Haustechnik sein. Da diese Bereiche häufig sehr unterschiedliche Sicherheitsanforderungen aufweisen, kann es sinnvoll sein, diese in verschiedene Sicherheitszonen aufzuteilen (siehe INF.1.M 23 Bildung von Sicherheitszonen).
- Vergabe von Zutrittsberechtigungen (siehe ORP.4 Identitäts- und Berechtigungsmanagement)
- Bestimmung eines Verantwortlichen für Zutrittskontrolle
  Dieser vergibt die Zutrittsberechtigungen an die einzelnen Personen entsprechend den in der Sicherheitspolitik festgelegten Grundsätzen.
- Definition von Zeitabhängigkeiten
  Es ist zu klären, ob zeitliche Beschränkungen der Zutrittsrechte erforderlich sind. Solche Zeitabhängigkeiten können etwa sein: Zutritt nur während der Arbeitszeit, Zutritt einmal täglich oder befristeter Zutritt bis zu einem fixierten Datum.
- Festlegung der Beweissicherung
  Hier ist zu bestimmen, welche Daten bei Zutritt zu und Verlassen von einem geschützten Bereich protokolliert werden. Dabei bedarf es einer sorgfältigen Abwägung zwischen den Sicherheitsinteressen des Systembetreibers und den Schutzinteressen der Privatsphäre des Einzelnen.
- Behandlung von Ausnahmesituationen
  Auch in Ausnahmesituationen sollten keine Unbefugten das Gebäude oder die Liegenschaften betreten können. Oberste Priorität ist allerdings sicherzustellen, dass im Brandfall alle Personen schnellstmöglich die gefährdeten Zonen verlassen können.

Ergänzend kann der Einbau von Ausweislesern verschiedenster Qualitäten, von Schleusen und Vereinzelungseinrichtungen sinnvoll sein. Zur Schlüsselverwaltung siehe INF.1.M 12 Schlüsselverwaltung.

Um ein umfassenderes Konzept umzusetzen, Flexibilität im Einsatz zu erhalten und um Transparenz und Nachprüfbarkeit sicherzustellen, ist der Einsatz eines IT-gestützten Systems zum Berechtigungsmanagement zu empfehlen (siehe Kapitel 3.1 Zutrittskontrollsystem und Berechtigungsmanagement).

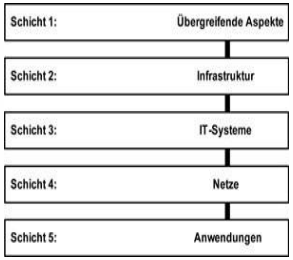
Die Terminals zur Zutrittskontrolle müssen gegen Manipulationen geschützt werden. Dafür müssen diese so angebracht werden, dass Vertraulichkeit bei der Eingabe von Daten gewährleistet ist. Außerdem sollten alle zur Dateneingabe erforderlichen Einheiten in einem Gerät kombiniert sein, also beispielsweise eine Tastatur zur PIN-Eingabe.

Befinden sich nicht alle Einheiten in einem Gerät, muss die Datenübertragung zwischen diesen verschlüsselt erfolgen. Werden also z. B. berührungslose Ausweisleser eingesetzt, so muss die Datenübertragung zwischen Karte und Leser verschlüsselt erfolgen.

Im Betrieb muss die Wirksamkeit aller technischen und organisatorischen Maßnahmen stetig kontrolliert werden. Es empfiehlt sich, vor allem an bekannten problematischen Stelle regelmäßig zu überprüfen, ob keine Möglichkeiten entstanden sind, um die Zutrittskontrolle zu umgehen, z. B. in Liefer- oder Raucherzonen.

Umsetzungshinweise zum Baustein INF 1

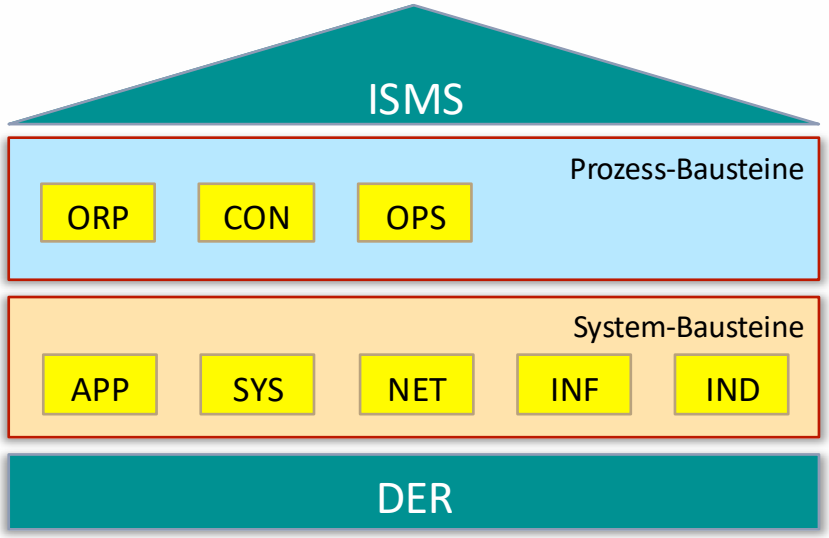
Schichtenmodell IT-Grundschutz-Kompendium



Quelle: BSI IT-Grundschutz Kataloge , Kap 2.1 Modellierung

Bisher:
„Systemorientiert“

Neu:
„Funktionsorientiert“

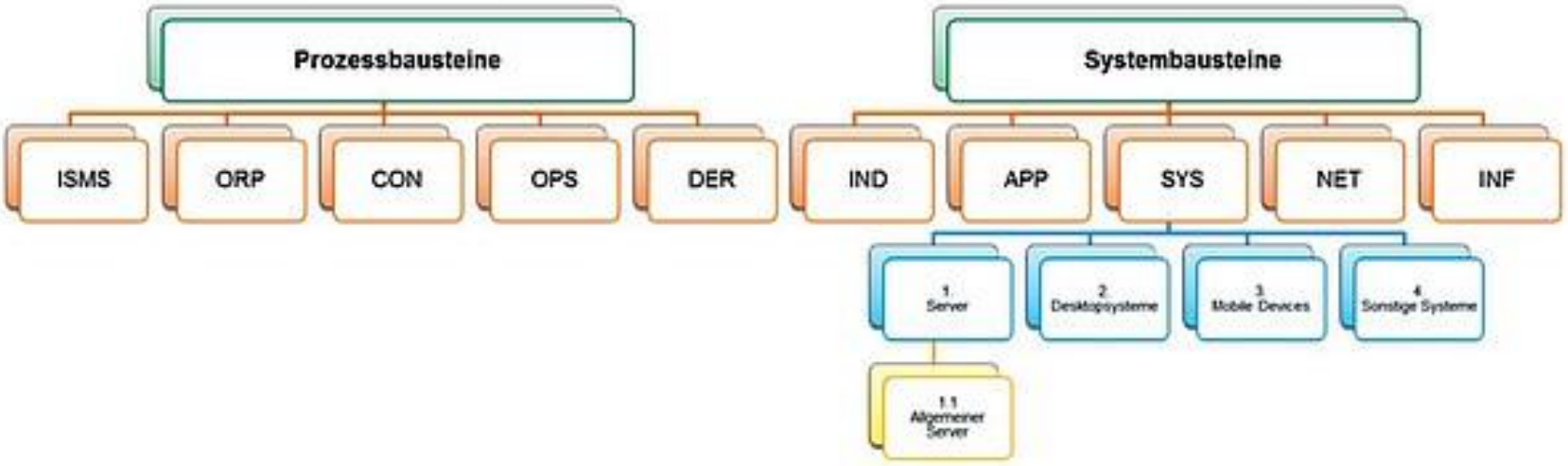


Quelle: BSI 200-2, S.108

ISMS	Sicherheitsmanagement
ORP	Organisation & Personal
CON	Konzepte & Vorgehensweisen
OPS	Sicherheitsaspekte des Betriebs
APP	Anwendungen
SYS	IT Systeme und Komponenten
NET	Netzwerke
INF	Physische Sicherheit
IND	Industrielle IT (SCADA ...)
DER	Detektion & Reaktion (auf Sicherheitsvorfälle)

+ Übergeordnete und prozesshafte Aspekte sind getrennt von Systemen
+ Bündelung von Zuständigkeiten
=> Annäherung an die Struktur der ISO 27001

Struktur des BSI Grundschutz-Kompendiums



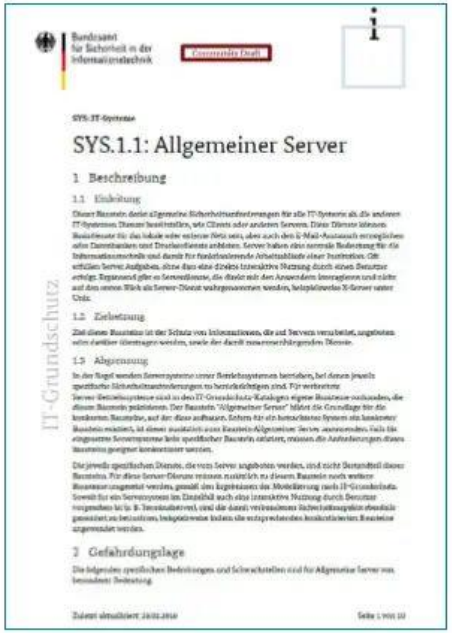
Typischer Aufbau eines Bausteins

Bausteine GS-Kompendium
Dokumentenstruktur



- Umfang: ca. 10 Seiten!
- Beschreibung
  - Einleitung
  - Zielsetzung
  - Abgrenzung
  - Verantwortliche
- Spezifische Gefährdungslage
- Anforderungen (keine Maßnahmen)
  - Basis-Anforderungen
  - Standard-Anforderungen
  - Anforderungen bei erhöhtem Schutzbedarf
- Referenzen auf weiterführende Informationen

Anlage: Kreuzreferenztabelle



Bundesamt für Sicherheit in der Informationstechnik

SYS.1.1: Allgemeiner Server

1 Beschreibung

1.1 Einleitung

1.2 Zielsetzung

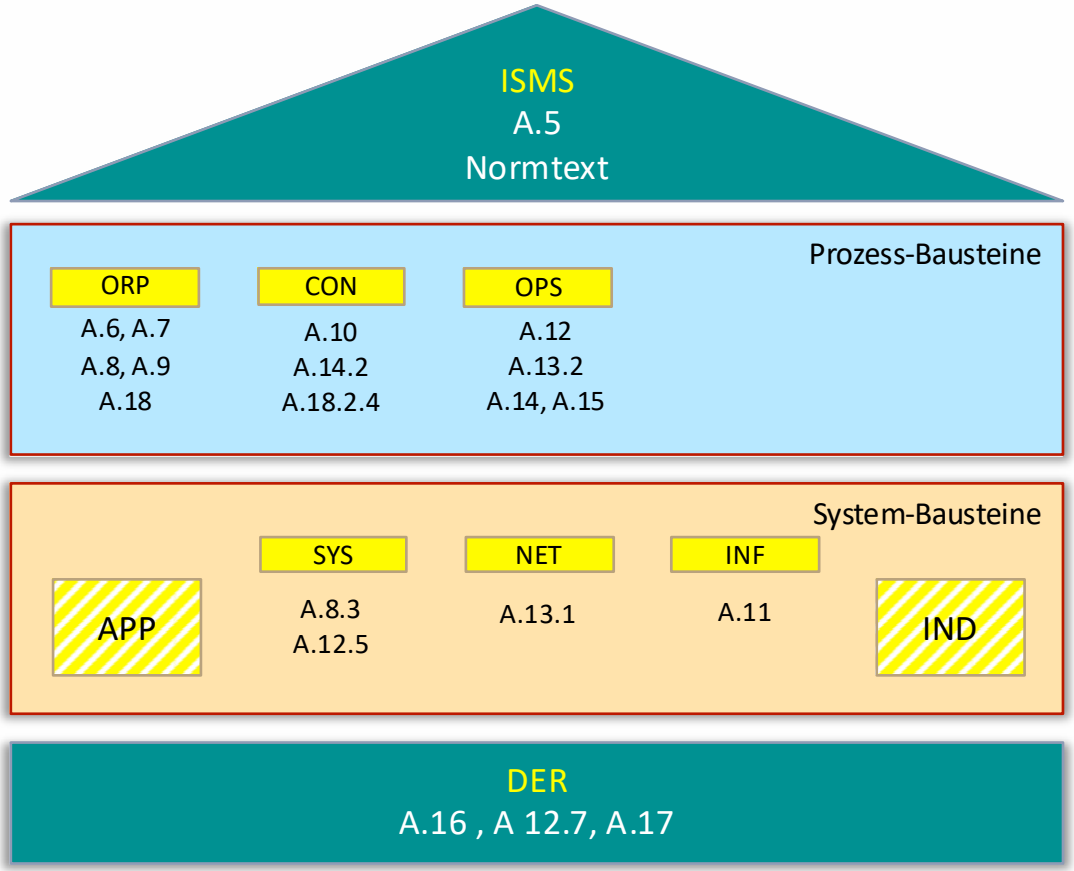
1.3 Abgrenzung

2 Gefährdungslage

IT-Grundschutz

H. Schildt, C. Wiemers | Seite 31

Grobe Abb. Schichten auf ISO 27001/2



Erkenntnisse:

- Der prozessorientierte Ansatz der ISO ist deutlich wiedererkennbar
- Die „Maßnahmenziele und Maßnahmen“ der ISO finden sich in den Anforderungen der GS-Bausteine praktisch vollständig wieder
- Der neue IT-Grundschutz geht darüber insbesondere im Bereich der Systembausteine deutlich hinaus
- Zu Bereichen wie industrieller IT und der Absicherung einzelner Anwendungen macht die ISO keine Vorgaben

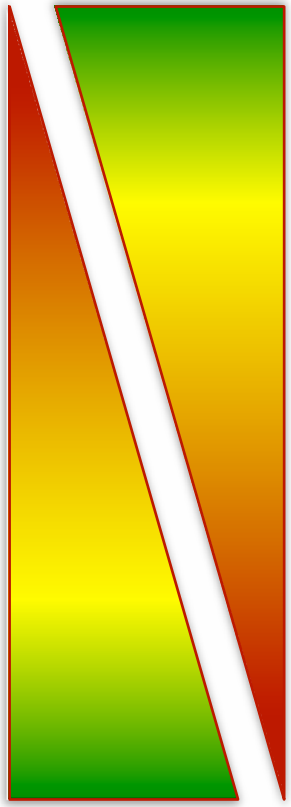
Einordnung des neuen IT-Grundschutzes

Freiheitsgrad

ISO 27001 nativ
ISO 27002

IT-Grundschutz-Kompendium (neu)

IT-Grundschutz-Katalog (alt)



Konkrete Vorgaben für die Umsetzung

„Prozessorientiert“
- Vorgabe der Methode („auf welche Weise ?“)

„Anforderungsorientiert“ :
- Beschreibung der Anforderungen („was ?“)
- Keine verbindliche Vorgabe von Maßnahmen („wie ?“)

„Maßnahmenorientiert“
- Maßnahmen verbindlich vorgegeben („wie ?“)

AGENDA

1. Motivation und Einführung
2. Neue Methodik
3. **Zertifizierung**
4. Kreuzreferenztabellen
5. Kombinierte Risiko-Analyse nach BSI 200-3
6. Fazit und Aufgaben
7. Vertiefung

Zertifikatsvoraussetzungen (bisher)

Seit 2006: Zertifizierung
„ISO 27001 auf Basis Grundschutz“



Auditor-Testat
„Grundschutz
Einstiegsstufe“

A

Auditor-Testat
„Grundschutz
Aufbaustufe“

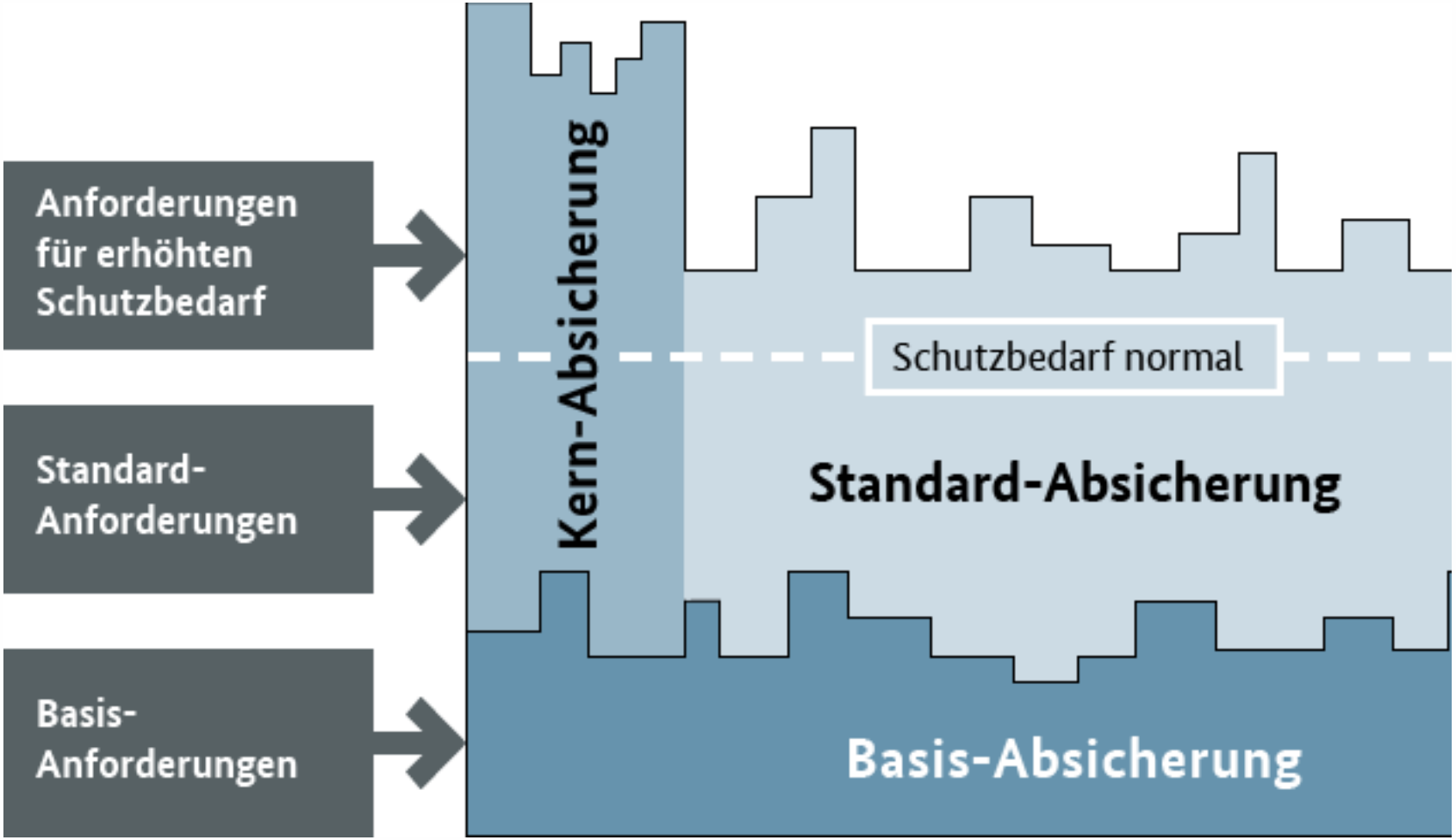
B

ISO 27001
auf Basis Grundschutz
„Zertifikatsstufe“

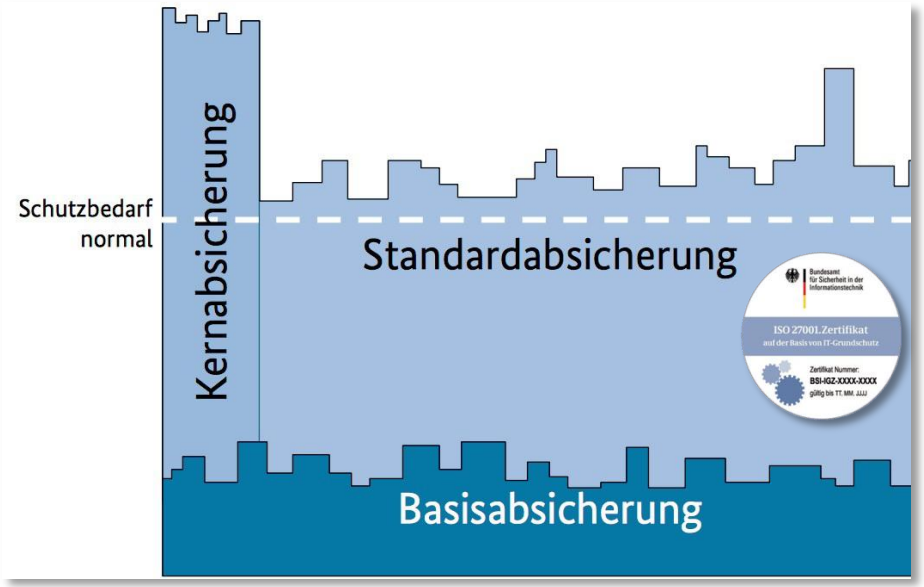
C

Zertifizierbar sind Verbünde, die (mindestens) die **Maßnahmen** der Zertifikatsstufe erfüllen

Schutzbedarfsstufen



Zertifikatsvoraussetzungen (neu)



Quelle: https://www.bsi.bund.de Kernpunkte der Modernisierung

Zertifizierbar sind Verbünde, die mindestens die **Anforderungen** der Standardabsicherung erfüllen

d.h. auch ein Teilverbund mit realisierter Kernabsicherung könnte zertifiziert werden

Basisabsicherung	=	grundlegende (Erst-)Absicherung (Mindestniveau, Einstieg)
Standardabsicherung	=	entspricht etwa dem bisherigen Grundschutz (Zertifikatsstufe)
Kernabsicherung	=	priorisiertet Teilbereich (oft mit erhöhtem Schutzbedarf)

Zertifizierungsstrategien



Aufwandstreiber:

- Identifikation der Werte
- Vollständige Risikoanalyse
- Ableiten Schutzmaßnahmen

Vorteile

- hoher Freiheitsgrad
- evulotionär zu gestalten

Risiken

- Vollständigkeit der Schutzmaßnahmen
- Sicherheitsniveau hängt stark von individueller Ausprägung ab

+ Risikoanalyse

+ Orientierung am GS-Kompendium wo passend (z.B. für Bereiche mittleren und hohen Risikos)

+ Mix generischer und detaillierter Anforderungen

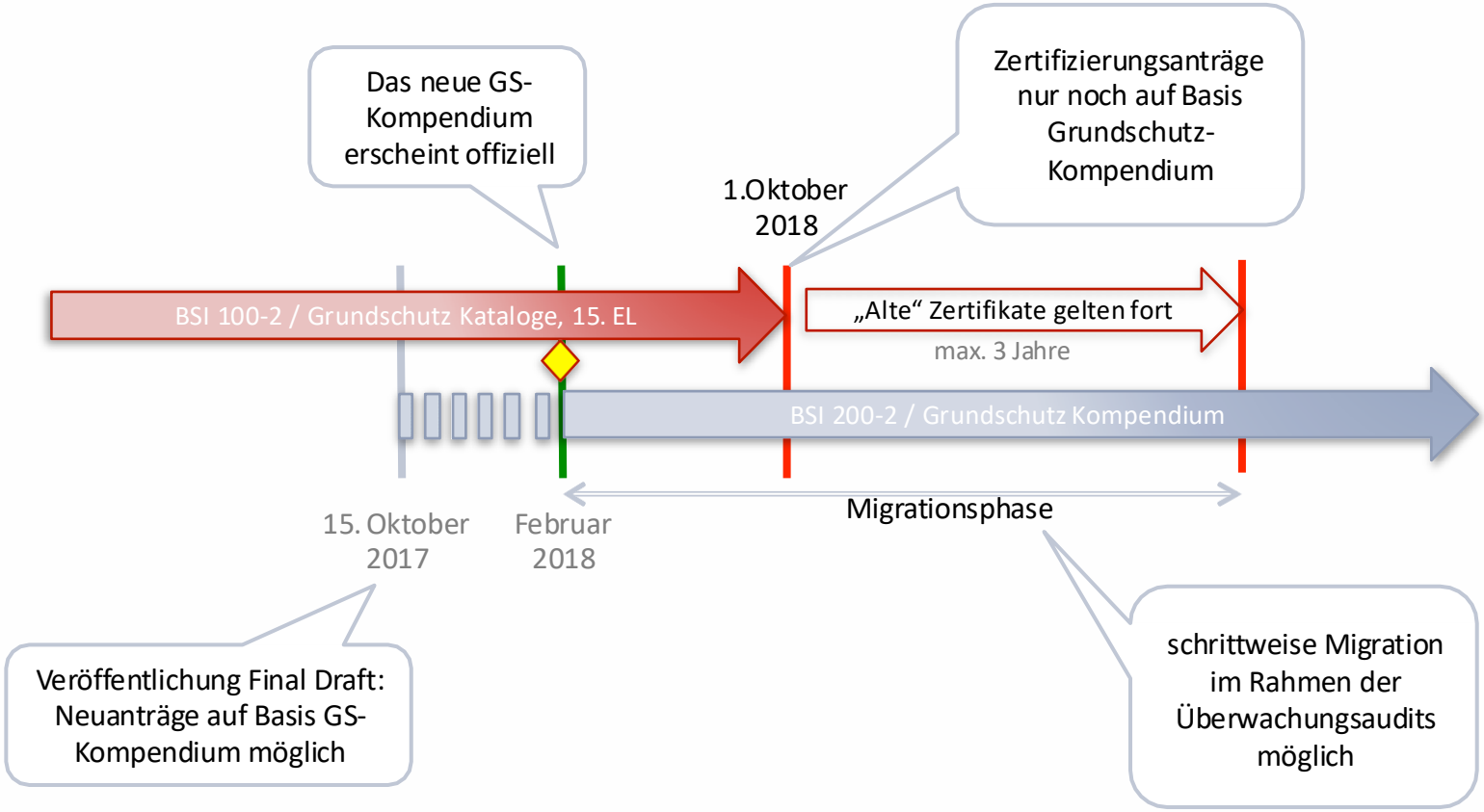
Aufwandstreiber

- Strukturanalyse
- Modellierung
- detaillierte Anforderungen

Vorteile

- Vergleichbarkeit
- Dokumentation
- standardisiertes Sicherheitsniveau
- Voraussetzung für öffentliche Aufträge

Zertifizierung neuer Grundschutz : Zeitplan



Erworbene Zertifikate gelten für die volle Laufzeit.

➔ Bei Ablauf der Gültigkeit Ende 2018 sollte ein Re-Zertifizierungsantrag ggf. vorgezogen werden um mit der Migration nicht unter Druck zu kommen

AGENDA

1. Motivation und Einführung
2. Neue Methodik
3. Zertifizierung
4. **Kreuzreferenztabellen**
5. Kombinierte Risiko-Analyse nach BSI 200-3
6. Fazit und Aufgaben
7. Vertiefung

Kreuzreferenztabelle zu elementaren Gefährdungen (1/3)

Die Kreuzreferenztabelle enthält die Zuordnung von elementaren Gefährdungen zu den Anforderungen. Anhand dieser Tabelle lässt sich ermitteln, welche elementaren Gefährdungen durch welche Anforderungen abgedeckt sind. Durch die Umsetzung der aus den Anforderungen abgeleiteten Sicherheitsmaßnahmen wird den entsprechenden elementaren Gefährdungen entgegengewirkt. Die Buchstaben in der zweiten Spalte (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit) zeigen an, welche Grundwerte der Informationssicherheit durch die Anforderung vorrangig geschützt werden.

Kreuzreferenztabelle zu elementaren Gefährdungen (2/3)

Die folgenden elementaren Gefährdungen sind für den Baustein CON.4 *Auswahl und Einsatz von Standardsoftware*

von Bedeutung.

- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.19 Offenlegung schützenswerter Informationen
- G 0.20 Informationen oder Produkte aus unzuverlässiger Quelle
- G 0.22 Manipulation von Informationen
- G 0.28 Software-Schwachstellen oder -Fehler
- G 0.29 Verstoß gegen Gesetze oder Regelungen
- G 0.31 Fehlerhafte Nutzung oder Administration von Geräten und Systemen
- G 0.39 Schadprogramme
- G 0.46 Integritätsverlust schützenswerter Informationen

Kreuzreferenztabelle zu elementaren Gefährdungen (3/3)

Elementare Gefährdungen Anforderungen	CIA-Werte	G 0.18	G 0.19	G 0.20	G 0.22	G 0.28	G 0.29	G 0.31	G 0.39	G 0.46
CON.4.A1				X					X	
CON.4.A2		X								
CON.4.A3						X		X		
CON.4.A4		X								
CON.4.A5		X								
CON.4.A6		X								
CON.4.A7				X						
CON.4.A8							X			
CON.4.A9		X						X		
CON.4.A10	CIA	X								
CON.4.A11	CIA	X				X	X			
CON.4.A12	CI		X		X					X

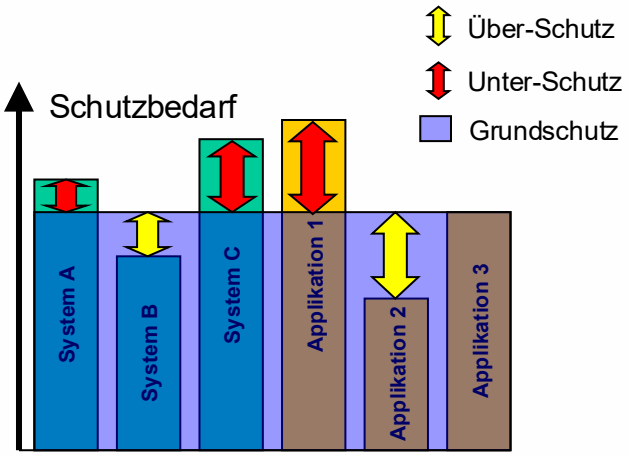
AGENDA

1. Motivation und Einführung
2. Neue Methodik
3. Zertifizierung
4. Kreuzreferenztabellen
5. **Kombinierte Risiko-Analyse nach BSI 200-3**
6. Fazit und Aufgaben
7. Vertiefung

Verfahren für den Umgang mit Risiken

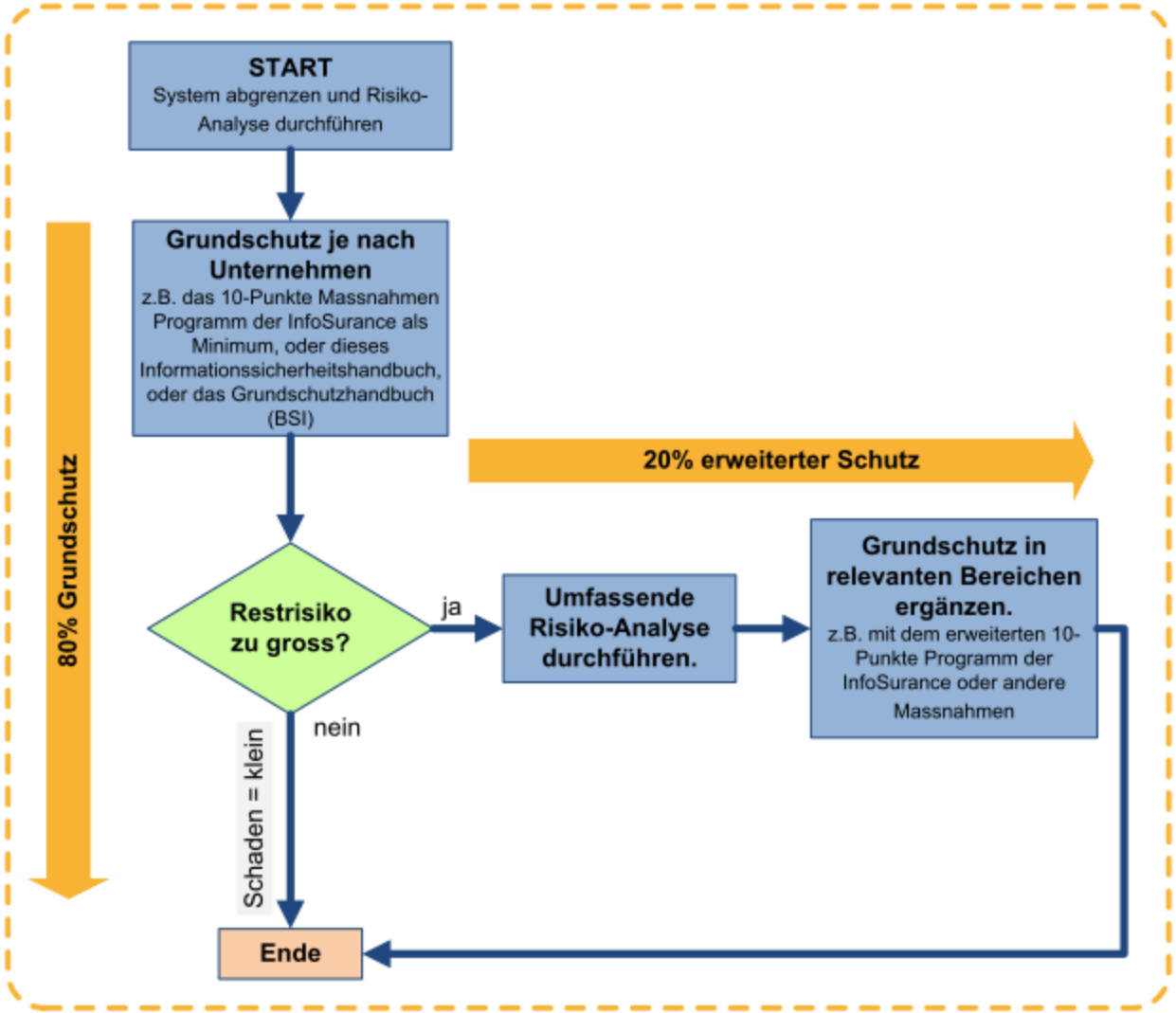
- Grundschutz (z. B. gemäss BSI)
  - Standardisierte Massnahmen
  - Generelle Risikobetrachtung
- Risikoanalyse
  - Spezifische Massnahmen
  - Detaillierte Risikobetrachtung





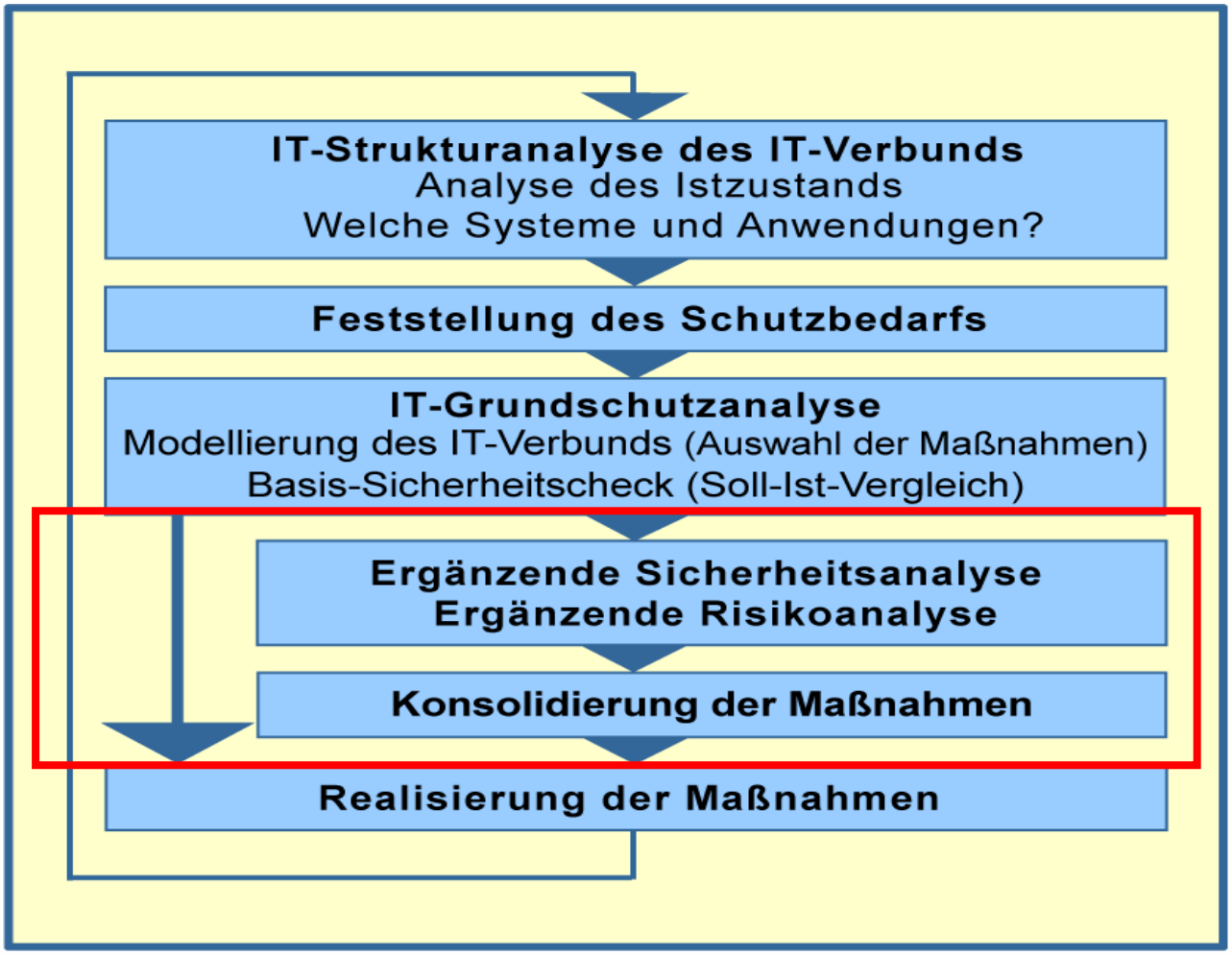
- Kombinierter Ansatz (zweistufiges Vorgehen, z. B. gemäss BSI)
  - Grundschutz bei Schutzbedarf klein und mittel
  - Risikoanalyse bei Schutzbedarf hoch und sehr hoch

Kombinierter Ansatz: Grundschutz und Risikoanalyse



Quelle: Informationssicherheitshandbuch 2011

BSI-Standard 200-3: Risikoanalyse auf Basis von IT-Grundschutz



AGENDA

1. Motivation und Einführung
2. Neue Methodik
3. Zertifizierung
4. Kreuzreferenztabellen
5. Kombinierte Risiko-Analyse nach BSI 200-3
6. **Fazit und Aufgaben**
7. Vertiefung

Fazit

1. Insbesondere durch
   a) Aufteilung der Bausteine in Anforderungen und Umsetzungshinweise
   b) Gliederung in Prozess- und Systembausteine
   c) Funktionsorientierung (Schichtenmodell)

1. haben sich IT-Grundschutz und ISO 27001 methodisch angenähert.
2. Die Anforderungsorientierung sollte den Aufwand in der Umsetzung reduzieren
3. Keine Revolution: Die Vorteile beider Vorgehensweisen bleiben erhalten

Aufgaben IT-Grundschutz nach BSI

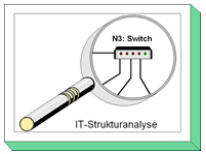
1. Leiten Sie 5 Massnahmen zum Thema *Schutz von Daten* aus dem IT-Grundschutz-Kompendium ab. Geben Sie zu jeder Massnahme eine damit mitigierte Gefährdung an.
2. Lesen Sie eine Umsetzungshinweise genau durch, und geben Sie den Initiierungsverantwortlichen an. Wie beurteilen Sie die entwickelte Massnahme bezüglich Detailgrad?
3. Versuchen Sie die auf Folie 31 aufgeführte Kreuzreferenz-Tabelle nachzuvollziehen. Welche Aussage macht sie?
4. Beschreiben Sie die Unterschiede zwischen den IT-Grundschutzkatalogen und ISO 27002.

BSI Onlinekurs: Schulung Grundschutz

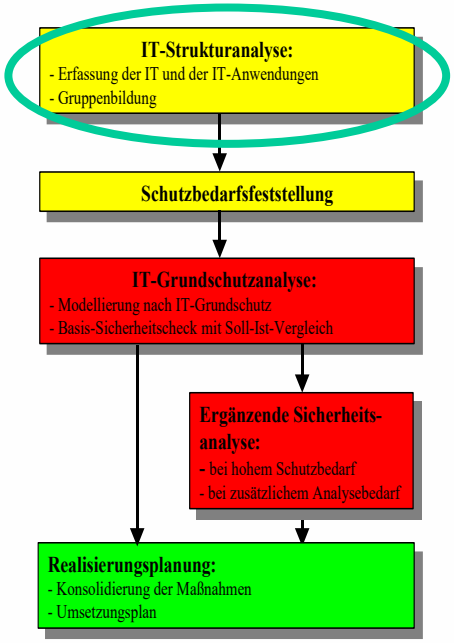
https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/Zertifizierte-Informationssicherheit/IT-Grundschutzschulung/Online-Kurs-IT-Grundschutz/Lektion_1_Einstieg/Lektion_1_node.html

AGENDA

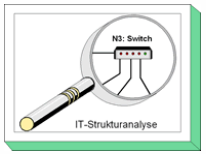
1. Motivation und Einführung
2. Neue Methodik
3. Zertifizierung
4. Kreuzreferenztabellen
5. Kombinierte Risiko-Analyse nach BSI 200-3
6. Fazit und Aufgaben
7. **Vertiefung**



IT-Strukturanalyse – Erhebung Netzwerkplan

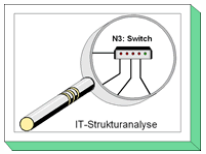


- Netzwerkplan *aktualisieren*
  - Netzwerkpläne sind meist nicht auf dem aktuellsten Stand
  - Entsprechende Informationen beschaffen bei IT-Verantwortlichen, Administratoren resp. Netz- und Systemmanagement
- Netzwerkplan *auswerten*
  - Welche IT-Systeme gibt es? (Clients, Server, Netzwerk-Komponenten etc.)
  - Welche Verbindungen zw. diesen Systemen?
  - Welche Verbindungen nach aussen (Einwahl, Internet, VPN etc.)



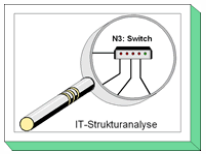
IT-Strukturanalyse – Komplexitätsreduktion

- Gleichartige Komponenten zu Gruppen zusammenfassen
- Mögliche Gruppierungskriterien
  - Systeme von gleichem Typ
  - Systeme mit gleicher oder nahezu gleicher Konfiguration
  - Systeme mit gleicher oder nahezu gleicher Netzwerkanbindung
  - Systeme mit gleichen administrativen und infrastrukturellen Rahmenbedingungen
  - Systeme, welche für gleiche Aufgaben genutzt werden
  - Systeme, welche den gleichen Schutzbedarf aufweisen



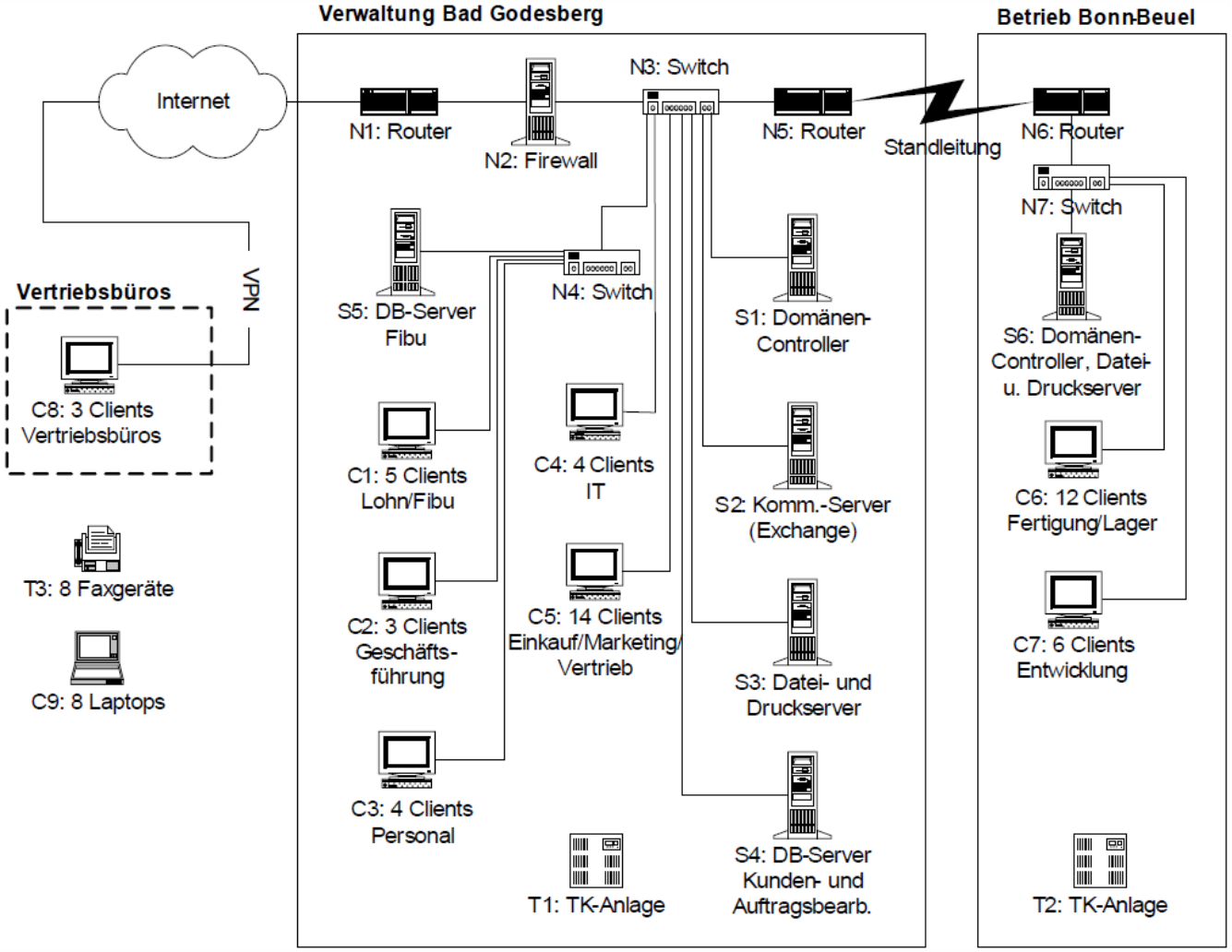
IT-Strukturanalyse – Komplexitätsreduktion

- Die bei der Komplexitätsreduktion entstandenen Gruppen werden fortan wie einzelne Objekte behandelt
- Wichtig: Keine Komponenten mit zu unterschiedlichem Schutzbedarf zusammen fassen, Beispiele:
  - Clients der Geschäftsleitung nicht in Gruppe der „normalen“ Clients integrieren
  - Dito für Clients von Entwicklungsabteilung, Personalabteilung, Buchhaltung und IT-Administration
  - Sie alle haben einen erhöhten Schutzbedarf

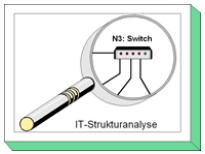


IT-Strukturanalyse – Komplexitätsreduktion

Beispiel für das Resultat einer Komplexitätsreduktion (Gruppen gleichartiger Komponenten)



Quelle: BSI Webkurs IT-Grundschutz



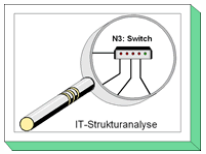
IT-Strukturanalyse – Erhebung IT-Systeme

Konsolidierung der Resultate der Komplexitätsreduktion (vgl. letzte Folie, Auflistung nicht abschliessend)

Nr.	Beschreibung	Plattform	Standort	Anzahl	Status	Benutzer/Administrator
S1	Domänen-Controller	Windows Server 2003	BG, R. 1.02 (Serverraum)	1	in Betrieb	alle IT-Benutzer/ IT-Administration
S4	DB-Server Kunden- und Auftragsbearbeitung	Windows Server 2003	BG, R. 1.02 (Serverraum)	1	in Betrieb	Marketing und Vertrieb, Fertigung, Lager/ IT-Administration
C5	Clients Kunden- und Auftrags-bearbeitung	Windows Vista	BG, R. 2.03 – 2.09	14	in Betrieb	Einkauf, Marketing und Vertrieb/ IT-Administration
C7	Clients in Entwicklungsabteilung	Windows Vista	Beuel, R. 2.14 – 2.20	6	in Betrieb	Entwicklung/ IT-Administration
C8	Clients in Vertriebsbüros	Windows Vista	Vertriebsbüros (Berlin, Hamburg, München)	3	in Betrieb	Mitarbeiter in Vertriebsbüros/ IT-Administration
N4	Switch für Personalabteilung	Switch	BG, R. 1.02 (Serverraum)	1	in Betrieb	alle IT-Benutzer/ IT-Administration
N5	Router zur Anbindung des Standorts Beuel	Router	BG, R. 1.02 (Serverraum)	1	in Betrieb	alle Mitarbeiter in BG/ IT-Administration
T1	Telefonanlage BG	ISDN-TK-Anlage	BG, R. 1.01	1	in Betrieb	alle Mitarbeiter in BG/ IT-Administration

Legende: Die IT-Systeme sind typweise durchnummeriert. Der vorangestellte Buchstabe kennzeichnet den Typ: S = Server, C = Client, N = Netzkomponente, T = Telekommunikationskomponente.

Quelle: BSI Webkurs IT-Grundschutz



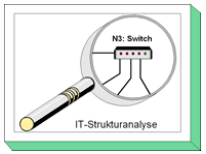
IT-Strukturanalyse – Zuordnung von Systemen und Anwendungen

- Der Schutzbedarf eines IT-Systems hängt vom Schutzbedarf der Anwendungen ab, welche es unterstützt
- IT-Systeme (Server, Clients) und Anwendungen werden einander deshalb zugeordnet

Nr.	Beschreibung	Personenbezogene Daten	C2	C5	C6	C8	C9	S1	S3	S4	S6
A4	Auftrags- und Kundenverwaltung	X	X	X	X	X	X			X	
A5	Benutzerauthentisierung	X						X			X
A9	Druckservice BG								X		
A10	Druckservice Beuel										X
A13	Application Gateway										

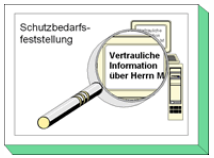
A = Anwendung, S = Server, C = Client

Quelle: BSI Webkurs IT-Grundschutz

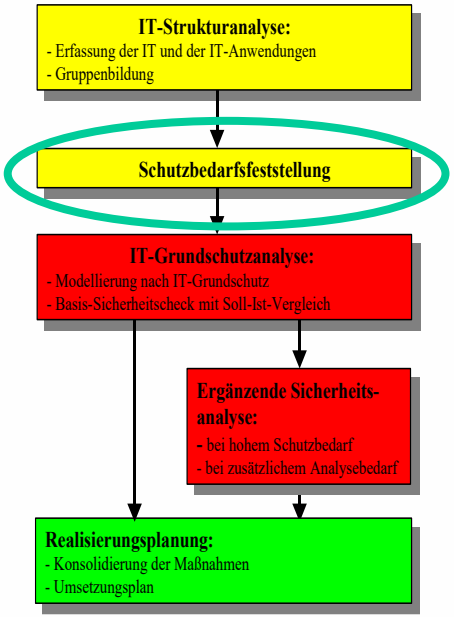


IT-Strukturanalyse – Zuordnung von Systemen und Anwendungen

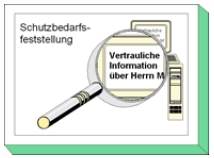
- Für den *Schutzbedarf eines Systems* ist diejenige Anwendung mit den *höchsten Sicherheitsanforderungen* (bezüglich Vertraulichkeit, Integrität und Verfügbarkeit) relevant
- Es gilt das sog. *Maximumprinzip* (vgl. zugehörige Folien)



Schutzbedarfsfeststellung – Ziel

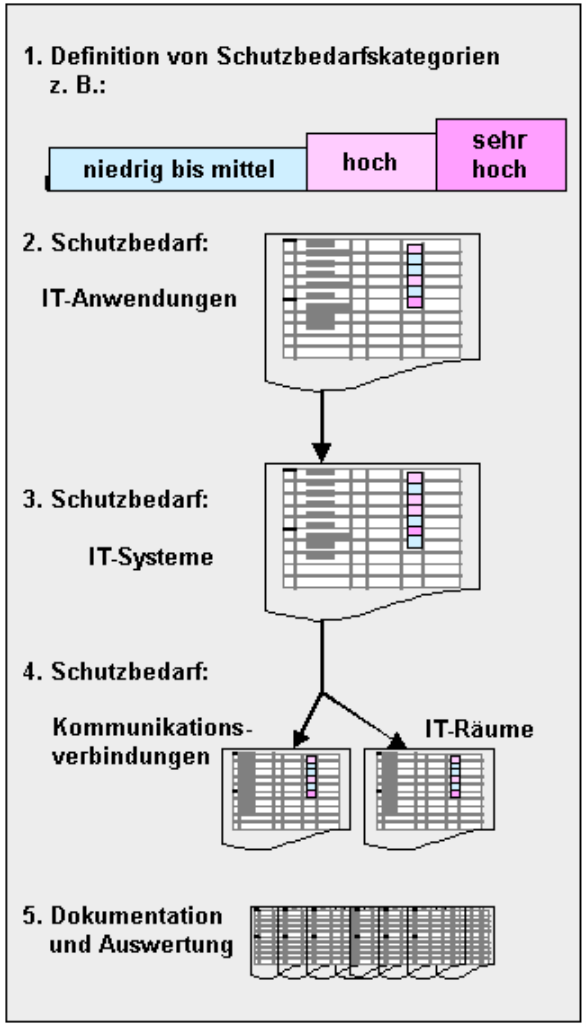


- Bestimmung des Schutzbedarfs des betrachteten Informationsverbunds
- Zu beantwortende Fragen:
  - Wie viel Schutz benötigen die identifizierten Objekte?
  - Wie kommt man zu einer begründeten und nachvollziehbaren Einschätzung des Schutzbedarfs?
  - Welche Objekte haben einen erhöhten Schutzbedarf?



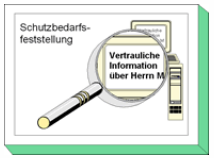
Schutzbedarfsfeststellung – Vorgehen

- Definition der Schutzbedarfskategorien entsprechend der Besonderheiten der Organisation (sog. Individualisierung)
- Schutzbedarfsfeststellung
  - von IT-Anwendungen und Daten
  - davon abgeleitet von IT-Systemen
  - davon abgeleitet von Kommunikationsverbindungen und IT-Räumen
- Dokumentation und Interpretation der Ergebnisse



Quelle: BSI Webkurs IT-Grundschutz

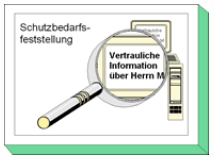
© Hochschule Luzern – Informatik



Schutzbedarfsfeststellung – Schutzbedarfskategorien

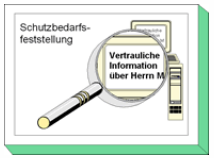
Die IT-Grundschutz-Vorgehensweise empfiehlt drei Schutzbedarfskategorien anhand der maximalen Schäden und Folgeschäden bei Verlust der Vertraulichkeit, der Integrität und der Verfügbarkeit:

- **Normal / Niedrig bis mittel**
  Begrenzte und überschaubare Schäden
- **Hoch**
  Beträchtliche Schäden möglich
- **Sehr hoch**
  Existentiell bedrohliche, katastrophale Schäden möglich



Schutzbedarfsfeststellung – Individualisierung der Kategorien

- Die Definition der Auswirkungen von Schadensereignissen einer bestimmten Kategorie muss die individuellen Eigenschaften resp. Besonderheiten der Organisation berücksichtigen
- Folgende typischen Schadszenarien können der Definition zu Grunde gelegt werden
  - Verstoss gegen Gesetze/Vorschriften/Verträge
  - Beeinträchtigung des informationellen Selbstbestimmungsrechts
  - Beeinträchtigung der persönlichen Unversehrtheit
  - Beeinträchtigung der Aufgabenerfüllung
  - Negative Aussenwirkung (Imageschäden)
  - Finanzielle Auswirkungen



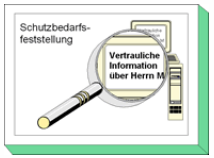
Schutzbedarfsfeststellung – Individualisierung der Kategorien

- **Schutzbedarfskategorie niedrig bis mittel:**

  Ein möglicher Schaden hätte nur begrenzte und überschaubare Auswirkungen auf die RECPLAST GmbH:

  - Bei Verstößen gegen Gesetze, Vorschriften oder Verträge drohen allenfalls geringfügige juristische Konsequenzen oder Konventionalstrafen.
  - Beeinträchtigungen des informationellen Selbstbestimmungsrechts und der Missbrauch personenbezogener Daten hätten nur geringfügige Auswirkungen auf die davon Betroffenen und würden von diesen toleriert.
  - Die persönliche Unversehrtheit wird nicht beeinträchtigt.
  - Die Abläufe bei RECPLAST werden allenfalls unerheblich beeinträchtigt. Ausfallzeiten von mehr als 24 Stunden können hingenommen werden.
  - Das Ansehen des Unternehmens bei Kunden und Geschäftspartnern wird nicht beeinträchtigt.
  - Der mögliche finanzielle Schaden ist kleiner als 50.000 Euro.

Quelle: BSI Webkurs IT-Grundschutz



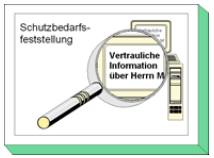
Schutzbedarfsfeststellung – Individualisierung der Kategorien

- **Schutzbedarfskategorie hoch:**

  Ein möglicher Schaden hätte beträchtliche Auswirkungen auf die RECPLAST GmbH:

  - Bei Verstößen gegen Gesetze, Vorschriften oder Verträge drohen schwerwiegende juristische Konsequenzen oder hohe Konventionalstrafen.
  - Beeinträchtigungen des informationellen Selbstbestimmungsrechts und der Missbrauch personenbezogener Daten hätten beträchtliche Auswirkungen auf die davon Betroffenen und würden von diesen nicht toleriert.
  - Die persönliche Unversehrtheit wird nicht beeinträchtigt.
  - Die Abläufe bei RECPLAST werden erheblich beeinträchtigt. Ausfallzeiten dürfen maximal 24 Stunden betragen.
  - Das Ansehen des Unternehmens bei Kunden und Geschäftspartnern wird erheblich beeinträchtigt.
  - Der mögliche finanzielle Schaden liegt zwischen 50.000 und 500.000 Euro.

Quelle: BSI Webkurs IT-Grundschutz



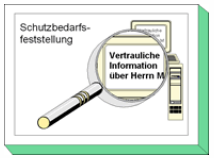
Schutzbedarfsfeststellung – Individualisierung der Kategorien

- **Schutzbedarfskategorie sehr hoch:**

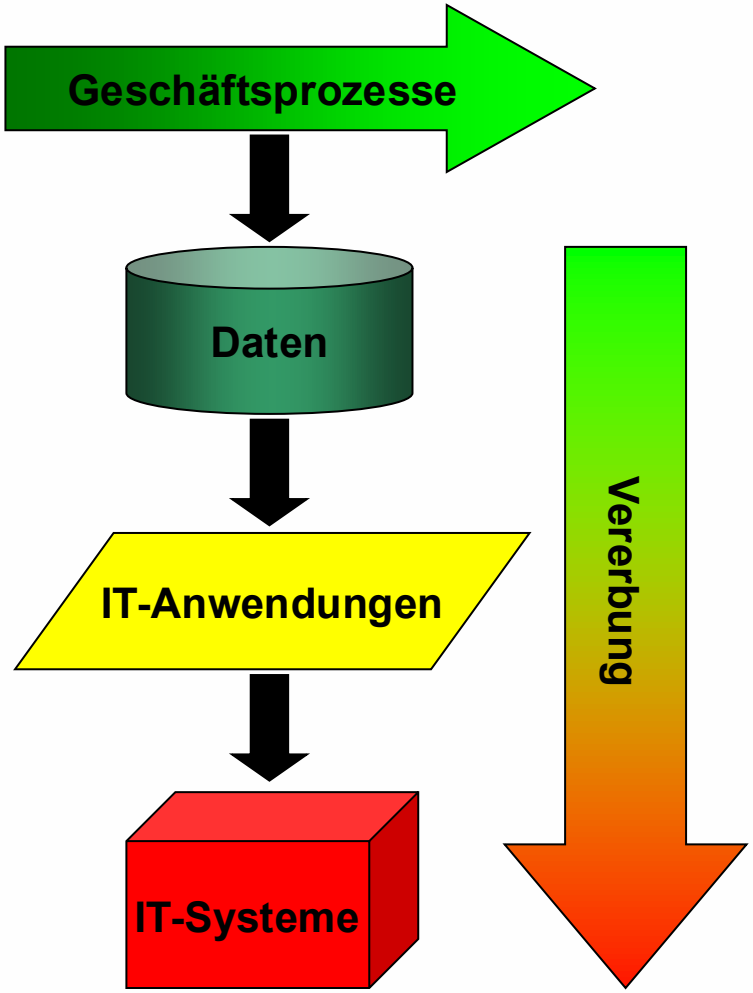
  Ein möglicher Schaden hätte katastrophale Auswirkungen:

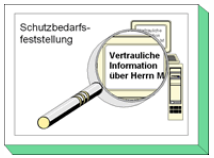
  - Bei Verstößen gegen Gesetze, Vorschriften oder Verträge drohen juristische Konsequenzen oder Konventionalstrafen, die die Existenz des Unternehmens gefährden.
  - Beeinträchtigungen des informationellen Selbstbestimmungsrechts und der Missbrauch personenbezogener Daten hätten ruinöse Auswirkungen auf die gesellschaftliche oder wirtschaftliche Stellung der davon Betroffenen.
  - Die persönliche Unversehrtheit wird nicht beeinträchtigt.
  - Die Abläufe bei RECPLAST werden so stark beeinträchtigt, dass Ausfallzeiten, die über 2 Stunden hinausgehen, nicht toleriert werden können.
  - Das Ansehen des Unternehmens bei Kunden und Geschäftspartnern wird grundlegend und nachhaltig beschädigt.
  - Der mögliche finanzielle Schaden liegt über 500.000 Euro.

Quelle: BSI Webkurs IT-Grundschutz

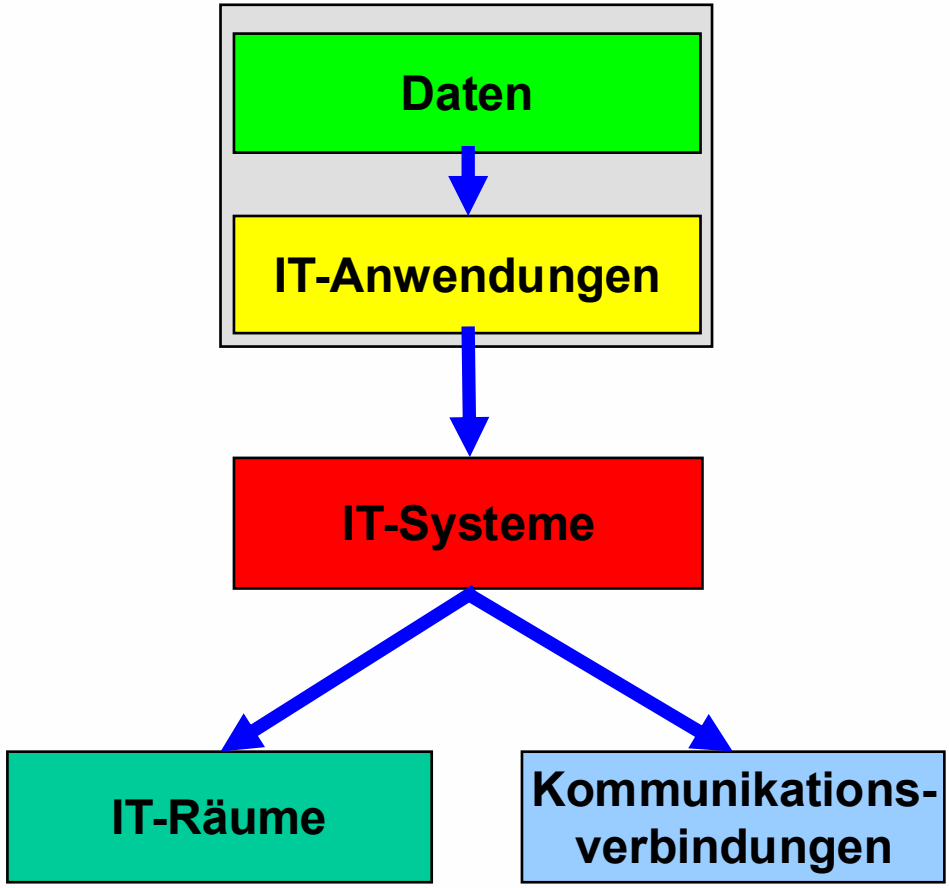


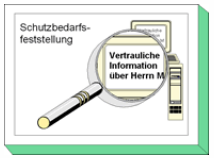
Schutzbedarfsfeststellung – Abhängigkeiten / Vererbung von Schutzbedarf



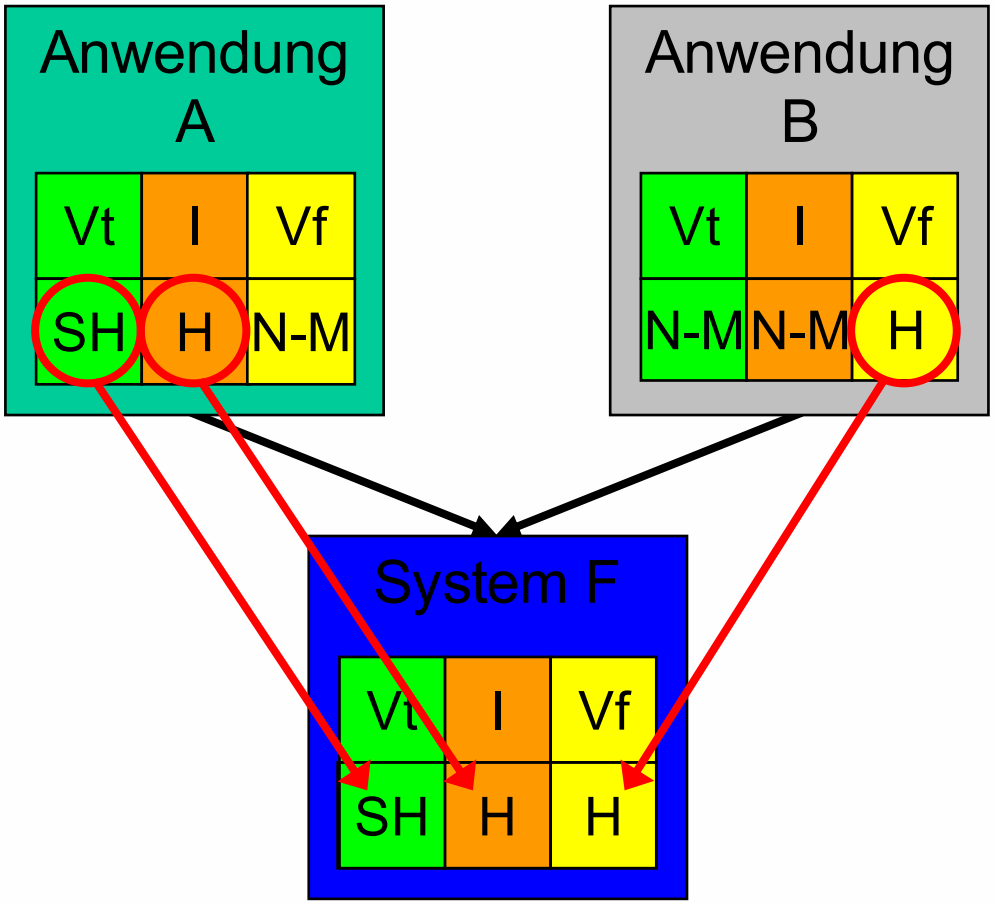


Schutzbedarfsfeststellung – Abhängigkeiten / Vererbung von Schutzbedarf



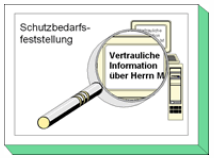


Schutzbedarfsfeststellung – Maximumprinzip



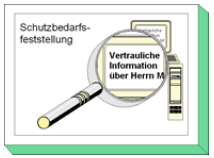
Legende:

Vt	Vertraulichkeit
I	Integrität
Vf	Verfügbarkeit
SH	Sehr hoch
H	Hoch
N-M	Niedrig bis mittel



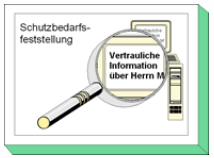
Schutzbedarfsfeststellung – Regeln

- **Maximumprinzip**
  Höchster Schutzbedarf der Anwendungen, welche ein System nutzen, gilt für das System
- **Kumulationseffekt**
  System hat höheren Schutzbedarf als die zugeordneten Anwendungen (*höherer* Schaden aufgrund von *gleichzeitigem* Ausfall von *mehreren* Anwendungen)
- **Verteilungseffekt**
  System hat niedrigeren Schutzbedarf als die zugeordnete Anwendung (Anwendung ist auf mehrere Systeme verteilt; auf dem betrachteten System laufen nur weniger wichtige Teile davon)



Schutzbedarfsfeststellung – Schutzbedarf von IT-Anwendungen

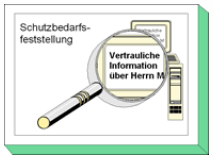
- Für alle IT-Anwendungen muss der Schutzbedarf für die drei Grundwerte Vertraulichkeit, Verfügbarkeit und Integrität bestimmt werden
- Grundlage: Schutzbedarf der verarbeiteten Daten
- Hilfsmittel: Die definierten Schadensszenarien
- Die Szenarien müssen dabei aus der Sicht der Nutzer der IT-Anwendungen betrachtet werden ➔ „Was wäre, wenn...“-Fragen stellen
- Die evaluierten Schutzbedarfskategorien müssen begründet und dokumentiert werden (auch für die GL verständlich!)



Schutzbedarfsfeststellung – Schutzbedarf von IT-Anwendungen

Schutzbedarfsfeststellung			
Nr.	**Bezeichnung**	**Schutzbedarf**	**Begründung**
A1	Personaldaten-verarbeitung	Vertraulichkeit: hoch	Personaldaten sind besonders schutzbedürftige Daten, deren Missbrauch die Betroffenen erheblich beeinträchtigen kann.
		Integrität: normal	Fehler werden rasch erkannt und können entweder aus der Datensicherung eingespielt oder durch Eingabe korrigiert werden.
		Verfügbarkeit: normal	Ausfälle bis zu einer Woche können mit manuellen Verfahren überbrückt werden.
A5	Benutzerauthen-tisierung	Vertraulichkeit: normal	Die Passwörter sind verschlüsselt gespeichert und damit praktisch nicht zugänglich.
		Integrität: hoch	Der hohe Schutzbedarf ergibt sich daraus, dass sich alle Mitarbeiter hierüber identifizieren.
		Verfügbarkeit: hoch	Bei Ausfall dieser Anwendung ist keine Identifizierung und damit keine Ausführung von IT-Verfahren möglich. Ein Ausfall ist allenfalls bis zu 24 Stunden tolerabel.
A12	Internet-Zugang	Vertraulichkeit: normal	Es werden keine vertraulichen Daten verarbeitet.
		Integrität: normal	Fehlerhafte Daten können in der Regel leicht erkannt werden.
		Verfügbarkeit: hoch	Die Recherche im Internet ist für einige Abteilungen wichtig (insbesondere die Einkaufsabteilung). Ein Ausfall ist höchstens 24 Stunden hinnehmbar.

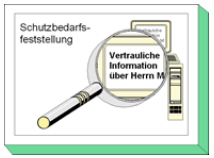
Quelle: BSI Webkurs IT-Grundschutz



Schutzbedarfsfeststellung – Schutzbedarf von IT-Systemen

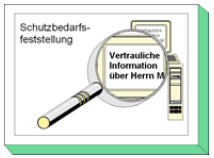
IT-System		Schutzbedarfsfeststellung	
Nr.	Bezeichnung	Schutzbedarf	Begründung
S1	Domänen-Controller	Vertraulichkeit: normal	Maximumprinzip gemäß Anwendung A5 (Benutzerauthentisierung)
		Integrität: hoch	Maximumprinzip gemäß Anwendung A5 (Benutzerauthentisierung)
		Verfügbarkeit: normal	Gemäß Anwendung A5 (Benutzerauthentisierung) wäre der Schutzbedarf hoch. Er wurde als normal festgelegt, weil die Benutzer aus Bad Godesberg sich auch über den Domänen-Controller S6 in Beuel anmelden können. Ein Ausfall bis zu drei Tagen ist hinnehmbar (Verteilungseffekt).
S2	Kommunikationsserver	Vertraulichkeit: hoch	Maximumprinzip gemäß Anwendung A7 (E-Mail)
		Integrität: hoch	Maximumprinzip gemäß Anwendung A7 (E-Mail)
		Verfügbarkeit: hoch	Maximumprinzip gemäß Anwendung A7 (E-Mail)
S5	DB-Server Finanzbuchhaltung	Vertraulichkeit: hoch	Maximumprinzip, da hohe Vertraulichkeit bei Anwendungen A1 (Personaldatenverarbeitung) und A3 (Finanzbuchhaltung)
		Integrität: hoch	Maximumprinzip von Anwendung A3 (Finanzbuchhaltung)
		Verfügbarkeit: normal	Ausfälle können mittels manueller Verfahren überbrückt werden.

Quelle: BSI Webkurs IT-Grundschutz



Schutzbedarfsfeststellung – IT-Räume

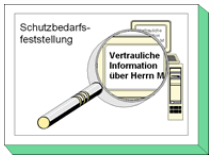
- *Vererbung* und *Maximumprinzip* berücksichtigen: Schutzbedarf bemisst sich am Schutzbedarf der IT-Systeme und der Informationen, welche im IT-Raum gelagert und verarbeitet werden
- Evtl. müssen *Kummulationseffekte* berücksichtigt werden: Höherer Schutzbedarf als für die einzelnen Objekte im Raum, z. B. bei gespiegelten (redundanten) Servern mit normalen Verfügbarkeitsanforderungen (➔ Erklärung?)



Schutzbedarfsfeststellung – IT-Räume

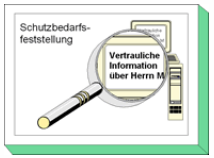
Raum				Schutzbedarf		
Bezeichnung	**Art**	**Lokation**	**IT-Systeme**	**Vertraulichkeit**	**Integrität**	**Verfügbarkeit**
BG, R. 1.01	Technikraum	Verwaltungsgebäude	TK-Anlage T1	normal	normal	hoch
BG, R. 1.02	Serverraum	Verwaltungsgebäude	S1 bis S5 N1 bis N5	hoch	hoch	hoch
Beuel, R. 2.01	Serverraum	Produktionshalle	S6, N6, N7	normal	normal	normal
Beuel, R. 2.10 – 2.13	Büroräume	Produktionshalle	C6, einige mit Faxgeräten	hoch	normal	normal

Quelle: BSI Webkurs IT-Grundschutz

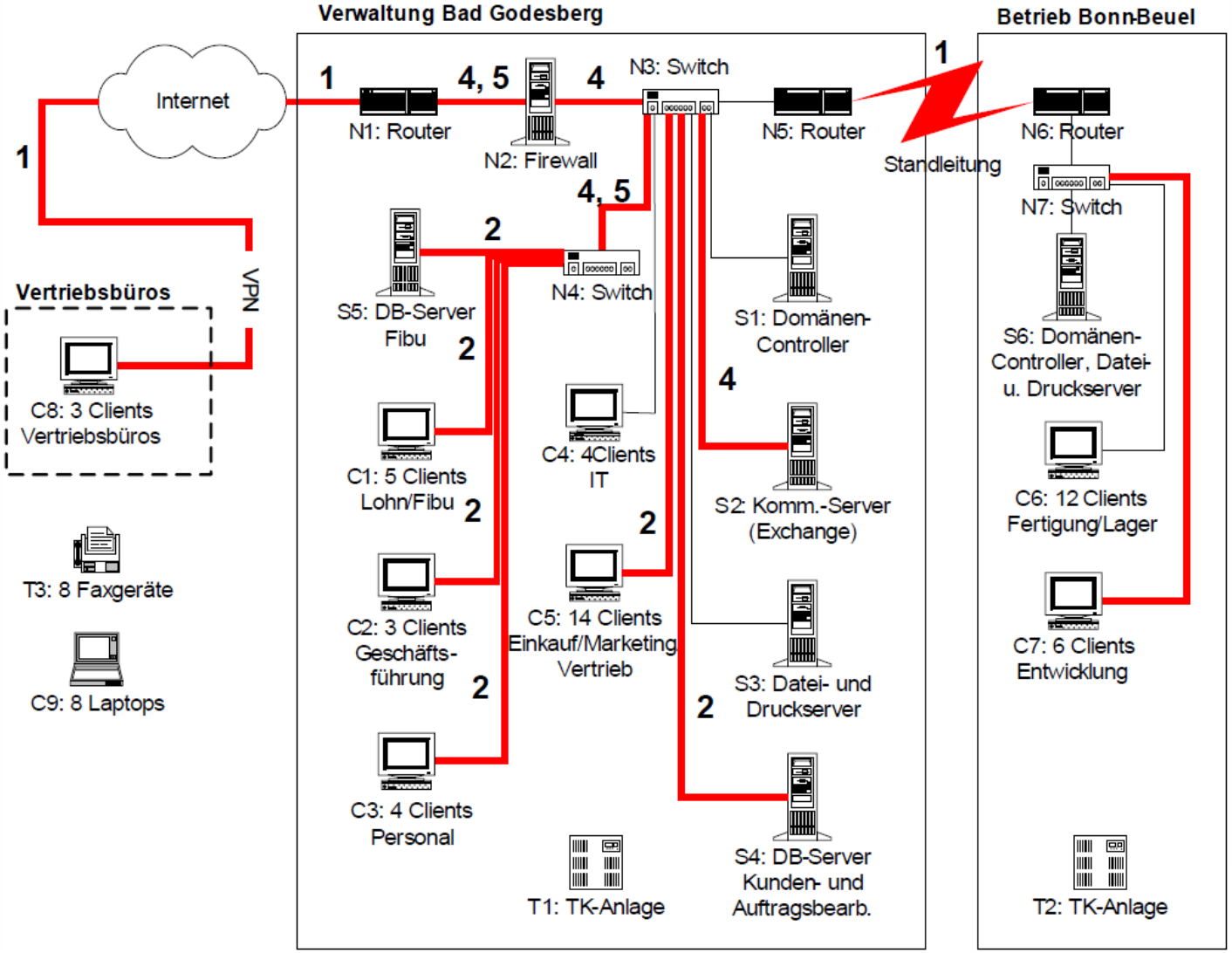


Schutzbedarfsfeststellung – Kommunikationsverbindungen

- Folgende Verbindungen sind als kritisch einzustufen
  - Verbindungen in ein öffentliches Netz (Internet, Telefonnetz etc.) oder über öffentlichen Grund
  - Verbindungen, über die besonders schützenswerte Informationen übertragen werden
  - Verbindungen, über die vertrauliche Informationen *nicht* übertragen werden dürfen
- Der Schutzbedarf der übertragenen Informationen leitet sich vom Schutzbedarf der miteinander verbundenen IT-Systeme ab

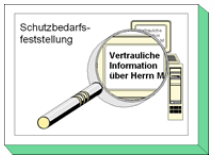


Schutzbedarfsfeststellung – Kommunikationsverbindungen



Rot:
kritische Verbindung

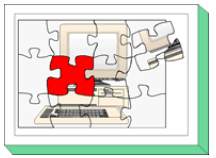
Quelle: BSI Webkurs IT-Grundschutz



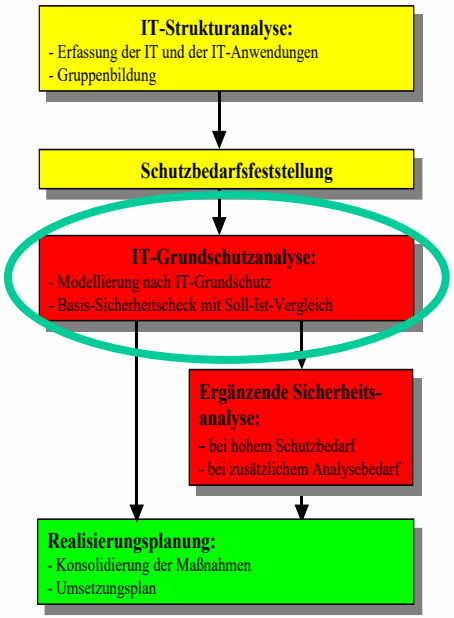
Schutzbedarfsfeststellung – Interpretation der Ergebnisse

Schutzbedarfskategorie:

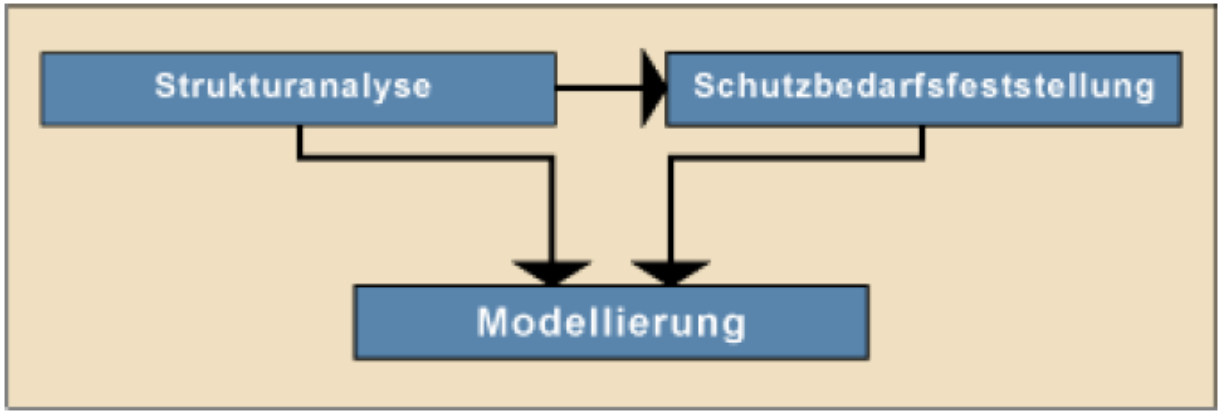
- **Normal / Niedrig bis mittel**
  Standard-Sicherheitsmassnahmen
- **Hoch**
  Standard-Sicherheitsmassnahmen + evtl. ergänzende Sicherheitsanalyse
- **Sehr hoch**
  Standard-Sicherheitsmassnahmen + zwingend ergänzende Sicherheitsanalyse



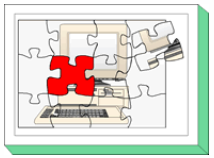
IT-Grundschutzanalyse – Modellierung nach IT-Grundschutz



- Nachbilden des erhobenen IT-Verbunds mit Hilfe der vorgegebenen IT-Grundschutz-Bausteine
- Ergebnis: **IT-Grundschutz-Modell**



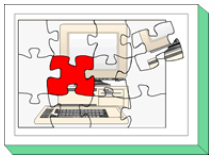
Quelle: BSI Webkurs IT-Grundschutz



IT-Grundschutzanalyse – Modellierung nach IT-Grundschutz

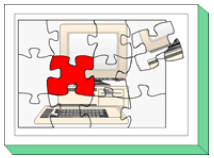


- Die Modellierung erfolgt entsprechend dem Schichtenmodell der IT-Grundschutz-Bausteine (Total 85 Bausteine)
- Schichtweise werden diejenigen Bausteine ausgewählt, welche für die Sicherheit des IT-Verbunds notwendig sind
- Ausgewählte Bausteine werden dem jeweiligen Zielobjekt (IT-Systeme, Räume etc.) zugeordnet
- Bei Bedarf können Bausteine im Rahmen der Modellierung modifiziert werden (z. B. Ergänzung um zusätzliche Massnahmen oder Konkretisierung von technischen Details)



IT-Grundschutzanalyse – Modellierung nach IT-Grundschutz

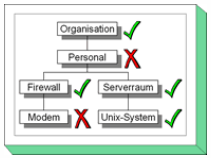
- Wichtig: Abschliessende Prüfung auf Vollständigkeit durchführen
  - Alle übergreifenden Aspekte berücksichtigt?
  - Alle Gebäude, Räume, Schutzschränke inkl. Verkabelung im Hinblick auf infrastrukturelle Sicherheit berücksichtigt?
  - Alle IT-Systeme einbezogen?
  - Alle netzwerktechnischen Sicherheitsaspekte berücksichtigt?
  - Alle Anwendungen berücksichtigt?
  - Alle Objekte ohne unmittelbar passenden Baustein durch andere Bausteine angemessen modelliert?



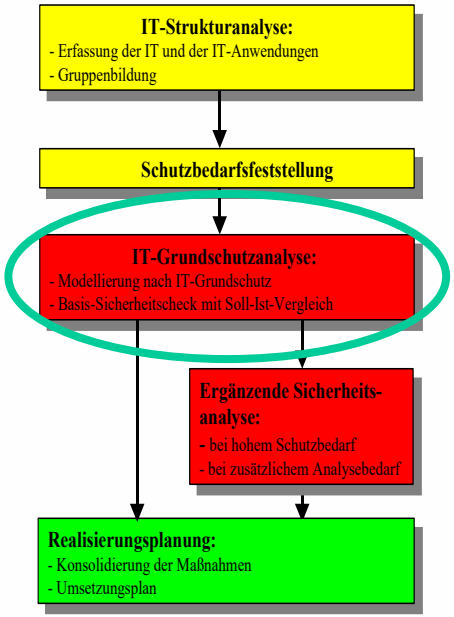
IT-Grundschutzanalyse – Modellierung nach IT-Grundschutz

Baustein	Zielobjekt	Hinweise
B 1.4 *Datensicherungskonzept*	Gesamte Organisation	Gilt einheitlich für alle Betriebsteile.
B 2.1 *Gebäude*	Verwaltungsgebäude	Der Baustein muss auf beide Gebäude getrennt angewendet werden.
B 2.1 *Gebäude*	Produktionshalle	
B 2.4 *Serverraum*	Serverraum BG, R. 1.02	Der Baustein muss auf beide Serverräume getrennt angewendet werden.
B 2.4 *Serverraum*	Serverraum Beuel, R. 2.05	
B 3.203 *Laptop*	C9	Die Laptops in den Vertriebsbüros, in Bad Godesberg und in Beuel werden von den Vertriebsmitarbeitern benutzt und sind in einer Gruppe zusammengefasst.
B 5.7 *Datenbanken*	A3 Finanzbuchhaltung	Die Datenbanksysteme unterscheiden sich bezüglich ihrer Server, ihrer Benutzer und ihres Schutzbedarfs. Der Baustein ist daher getrennt auf beide Anwendungen anzuwenden.
B 5.7 *Datenbanken*	A4 Auftrags- und Kundenverwaltung	

Quelle: BSI Webkurs IT-Grundschutz



IT-Grundschutzanalyse – Basis-Sicherheitscheck

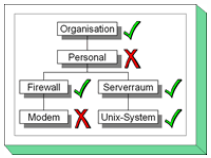


Der Basis-Sicherheitscheck soll folgende Fragen beantworten:

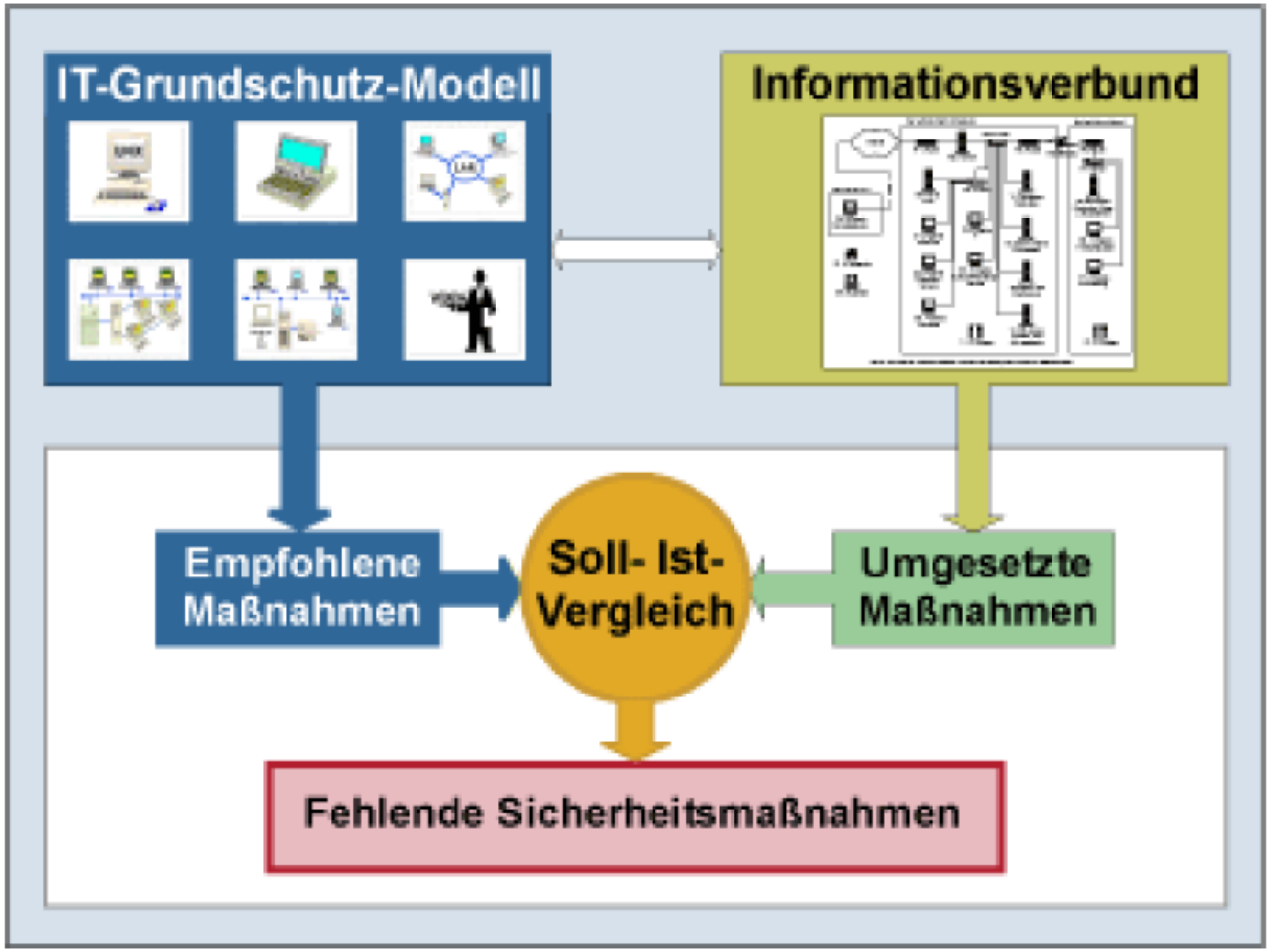
- Sind meine Informationen hinreichend geschützt?
- Was bleibt noch zu tun?

Vorgehen:

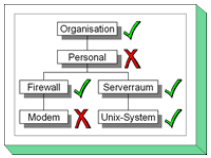
- Bereits umgesetzte Massnahmen mit den Empfehlungen der IT-Grundschutz-Kataloge vergleichen



IT-Grundschutzanalyse – Basis-Sicherheitscheck



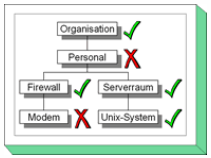
Quelle: BSI Webkurs IT-Grundschutz



IT-Grundschutzanalyse – Basis-Sicherheitscheck

Vorgehen im Detail:

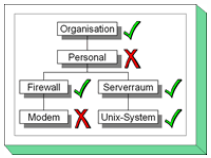
- Organisatorische Vorarbeiten leisten
- Soll-Ist-Vergleich durchführen
- Ergebnisse dokumentieren



IT-Grundschutzanalyse – Basis-Sicherheitscheck

Organisatorische Vorarbeiten:

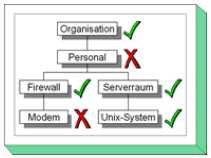
- Vorhandene Dokumente sichten
- Beizug externer Stellen klären/organisieren (Provider, Outsourcing-Partner etc.)
- Ermittlung der Interviewpartner (entsprechend Schichtenmodell)
  - Übergeordnete Aspekte: Personalabteilung, konzeptionell Verantwortliche etc.
  - Infrastruktur: Haustechnik, evtl. Externe
  - IT-Systeme / Netze: System- / Netzadministratoren
  - IT-Anwendungen: Anwendungsverantwortliche
- Termine planen



IT-Grundschutzanalyse – Basis-Sicherheitscheck

Soll-Ist-Vergleich:

- Erheben des Umsetzungsstatus der einzelnen Massnahmen mithilfe der Interviews
- Mögliche Umsetzungsstati
  - „Entbehrlich“ – benötigt immer eine Begründung!
  - „Ja“ – Massnahme vollständig umgesetzt
  - „Teilweise“ – Einzelne Aspekte nicht umgesetzt
  - „Nein“ – Massnahme überwiegend nicht umgesetzt
- Wichtig
  - Interviews dienen auch der Sensibilisierung
  - Aussagen verifizieren, Stichproben durchführen



IT-Grundschutzanalyse – Basis-Sicherheitscheck – Dokumentation

Maßnahme (erforderlich ab Siegelstufe)	entbehrl.	ja	teilweise	nein	Bemerkung/Begründung bei Nicht-Umsetzung
M 1.3 *Angepasste Aufteilung der Stromkreise* (A)				X	Bislang wurde die Elektroinstallation nicht geprüft.
M 1.7 *Handfeuerlöscher* (A)			X		Die betroffenen Mitarbeiter wurden nicht im Umgang mit den vorhandenen CO_2-Löschern geschult.
M 1.10 *Verwendung von Sicherheitstüren und -fenstern* (C)			X		Der Raum hat kein Sicherheitsfenster, nur eine Sicherheitstür.
M 1.15 *Geschlossene Fenster und Türen* (A)		X			Gemäß Dienstanweisung müssen Fenster und Türen bei Abwesenheit geschlossen sein.
M 1.18 *Gefahrenmeldeanlage* (Z)				X	Eine solche Anlage wurde bislang als unnötig und zu kostspielig eingestuft.
M 1.23 *Abgeschlossene Türen* (A)	X				Die Tür hat flurseitig einen Blindknauf.
M 1.24 *Vermeidung von wasserführenden Leitungen* (B)				X	Im Raum sind Heizkörper. Die Dichtigkeit der Leitungen wurde bislang nicht kontrolliert. Im Raum befindet sich ferner eine Klimaanlage mit Zuleitungen. Ein Rechner befindet sich direkt unter einer Zuleitung. Es fehlen Absperrventile außerhalb des Raums, mit denen die Wasserzufuhr zum Serverraum gezielt unterbrochen werden kann.
M 1.27 *Klimatisierung* (B)		X			
M 1.31 *Fernanzeige von Störungen* (Z)				X	Dies wurde bislang als unnötig teuer eingestuft.
M 1.52 *Redundanz, Modularität und Skalierbarkeit in der technischen Infrastruktur* (Z)	X				Es werden keine Ersatzgeräte vorrätig gehalten, da der IT-Lieferant vertraglich zugesichert hat, Ersatzgeräte innerhalb von 4 Stunden zu liefern.

Raum:
BG, R.1.02 Serverraum

Baustein:
B 2.4 Serverraum

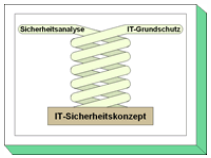
Befragung am:
19.08.2011

Befragung durch:
P. Muster

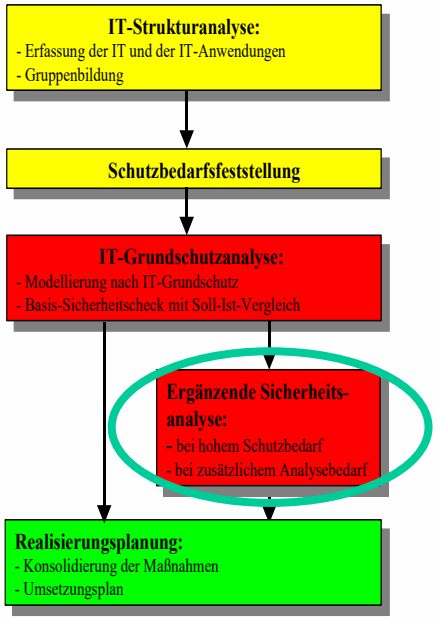
Befragte Personen:
A. Admin (Leiter IT)
M. Wachsam (Haustechnik)

© Hochschule Luzern – Informatik

Quelle: BSI Webkurs IT-Grundschutz

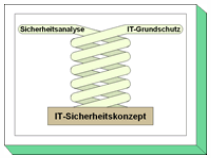


Ergänzende Sicherheitsanalyse



Sie ist durchzuführen, wenn für einzelne Zielobjekte

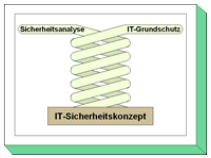
- die Schutzbedarfskategorie „hoch“ oder „sehr hoch“ in mindestens einem der drei Grundwerte vorliegt,
- kein geeigneter Baustein im Baustein-Katalog zu finden ist oder
- Objekte in untypischer Weise oder Einsatzumgebung betrieben werden



Ergänzende Sicherheitsanalyse - Ergebnis

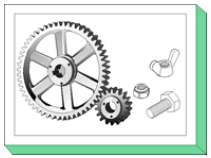
- Ergebnis der ergänzenden Sicherheitsanalyse
  - Grundschutzmassnahmen – allenfalls der Siegelstufe „zusätzlich“ – genügen

    oder
  - Es sind weitergehende Untersuchungen, z. B. eine klassische Risikoanalyse, notwendig

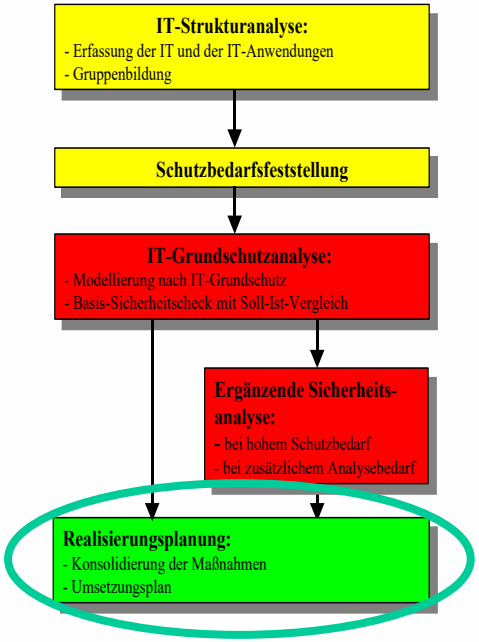


Ergänzende Sicherheitsanalyse – Vorgehensweisen für weitere Untersuchungen

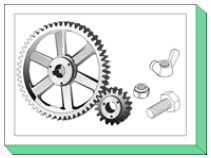
- Klassische Risikoanalyse
  - relevante Bedrohungen oder Schwachstellen ermitteln
  - Eintrittshäufigkeiten und Schadenshöhen schätzen
- Penetrationstest
  - Verhalten eines Angreifers simulieren
  - Blackbox- und Whitebox-Ansatz unterscheiden
- Differenz-Sicherheitsanalyse
  - Feststellen, welche der Sicherheitsmassnahmen über die Grundschutzmassnahmen hinausgehend realisiert sind
  - Vergleich durchführen, ob die ergriffenen Massnahmen den „Best Practices“ entsprechen, die sich in der Praxis für hochschutzbedürftige IT-Bereiche etabliert haben



Realisierungsplanung



- Ergebnisse sichten (fehlende *Sicherheitsmassnahmen* zusammenstellen)
- Massnahmen konsolidieren (überfl. M. streichen, verbleibende *konkretisieren* ➔ Massnahmenliste)
- *Aufwand* schätzen (finanziell, personell / einmalig, wiederkehrend)
- *Umsetzungsreihenfolge* festlegen (zuerst die-jenigen, welche Voraussetzung für andere sind)
- *Verantwortliche* und *Termine* bestimmen (für Realisierung und Überwachung von jeder Massnahme)
- Begleitende Massnahmen festlegen (*Sensibilisierung* und *Schulung*)
- Ergebnis: Realisierungsplan

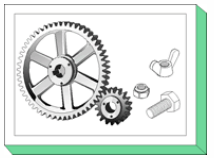


Beispiel eines Realisierungsplans

Zielobjekt: BG R. 1.02 Serverraum				
Baustein: B 2.4 Serverraum				
Maßnahme (erforderlich ab Siegelstufe)	**Umsetzung bis**	**Verantwortlich**	**Budget**	**Bemerkungen**
M 1.3 (A) *Angepasste Aufteilung der Stromkreise*	38. KW	Umsetzung: M. Wachsam Kontrolle: P. Muster	a) 0,- € b) 0,3 PT c) 0,- € d) 0 PT/Jahr	Die Elektro-Installation wird von der Haustechnik geprüft. Eine mindestens jährliche Überprüfung wird festgelegt.
M 1.7 (A) *Handfeuerlöscher*	38. KW	Umsetzung: M. Wachsam Kontrolle: P. Muster	a) 0,- € b) 0,3 PT c) 0,- € d) 0 PT/Jahr	Alle Mitarbeiter mit Zugangsberechtigung zum Serverraum sollen in die Handhabung der vorhandenen CO2-Löscher eingewiesen werden.
Z1: Einbau von Wasser ableitenden Blechen und Installation eines Wassermelders mit Sirene	39. KW	Umsetzung: M. Wachsam Kontrolle: P. Muster	a) 500,- € b) 1 PT c) 0,- € d) 0 PT/Jahr	Diese Maßnahme ersetzt Maßnahme M 1.24.

Legende: Z = Zusatzmaßnahme, PT = Personentage, KW = Kalenderwoche
a) Einmalige Investitionskosten b) Einmaliger Personalaufwand
c) Wiederkehrende Kosten d) Wiederkehrender Personalaufwand

Quelle: BSI Webkurs IT-Grundschutz



Erfahrungen beim Realisieren von Massnahmen

- Es tun!
- In kleinen Schritten, aber stetig
- Im Tagesgeschäft verdaubare Massnahmen
- Begreifen lassen, nicht vorschreiben
- Behinderungen minimieren
- Umsetzung und Wirksamkeit der Massnahmen regelmässig überprüfen (Aufrechterhaltung der Informationssicherheit)

Zusammenfassung

